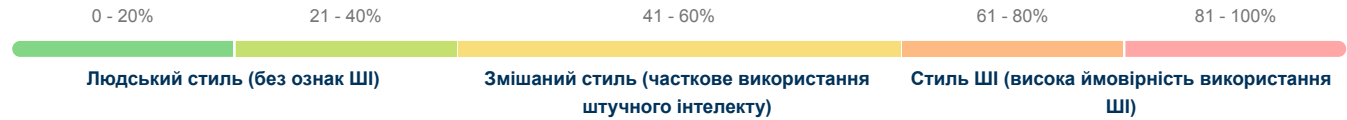




Результат пошуку відображає вірогідність того, чи був текст створений інструментом штучного інтелекту з використанням ChatGPT, Bing, Claude, Google Gemini, LLaMA, DeepSeek, Grok, Jasper або інших.

Текст показує ймовірність використання ШІ для окремих фрагментів документу і групує їх в 5 діапазонів згідно легенди.



Метадані

ДОКУМЕНТ

Заголовок

SmoliakovYe_MCS01_master_2026

Автор

Євген Смоляров

Науковий керівник / Експерт

Дмитро Агеєв

ІД документу

334470873

ОРГАНІЗАЦІЯ

Назва організації

GoIT Neoversity

підрозділ

GoIT Neoversity

ЗВІТ

Дата звіту

2026-07-05

Дата редагування

Індикатор Контенту ШІ

6%

Подробиці

Нижче наведено список фрагментів, розташованих за ймовірністю ШІ, від фрагментів із найвищою ймовірністю до фрагментів із найнижчою ймовірністю ШІ.

#	ФРАГМЕНТ	ЙМОВІРНІСТЬ ЗМІСТУ КОНТЕНТУ ШІ	КІЛЬКІСТЬ СЛІВ
1	Під час перевірки було встановлено, що інцидент м...	76%	35
2	Окрему проблему становлять спроби приховування сл...	75%	24
3	Основними перевагами використання IaC є: - авто...	75%	38
4	Перевагами використання автоматизованого реагуван...	75%	36
5	На момент реалізації проєкту політика перебувала ...	74%	18
6	Accessed: Jun. 27, 2026. 12. Microsoft, Azure r...	74%	12
7	Accessed: Jun. 27, 2026. 13. Microsoft, Azure Ar...	74%	11
8	27, 2026. 14. Microsoft, Azure Well-Architected ...	74%	48
9	Це дозволяє захистити журнали від модифікації або...	74%	24
10	Accessed: Jun. 27, 2026. 35. Microsoft, Immutabl...	74%	13
11	27, 2026. 32. Wazu, Wazu documentation, 2026. ...	74%	22

12	Accessed: Jun. 27, 2026. 34. NIST, SP 800-53 Re...	74%	20
13	Використання Azure Storage Immutability забезпечу...	74%	33
14	Accessed: Jun. 27, 2026. 18. Microsoft, Automate...	74%	15
15	Даний підхід забезпечує: - централізоване збері...	74%	30
16	27, 2026. 2. Microsoft, Log Analytics workspace ...	73%	27
17	27, 2026. 30. Microsoft, Data collection rules i...	73%	12
18	Accessed: Jun. 27, 2026. 37. Microsoft, Configur...	73%	19
19	Accessed: Jun. 27, 2026. 36 Cloud Security Alli...	73%	20
20	Accessed: Jun. 27, 2026. 29. Microsoft, Microsof...	72%	12
21	У найскладніші моменти вони своєчасно прийшли на д...	72%	16
22	Accessed: Jun. 27, 2026. 19 Microsoft, Azure Log...	72%	12
23	27, 2026. 23. MITRE, ATT&CK Tactic TA0006: Crede...	72%	74
24	72 3.7. Налаштування збору та централізац...	72%	19
25	Accessed: Jun. 27, 2026. 4. Microsoft, Microsoft...	72%	100
26	Після активації політики система автоматично блок...	72%	20
27	27, 2026. 20. NIST, SP 800-207: Zero Trust Archi...	72%	26
28	Accessed: Jun. 27, 2026. 118 31. Microsoft, ...	72%	12
29	Використання сервісів Microsoft Azure забезпечує ...	70%	27
30	У результаті система не дозволила видалити об'єкт...	70%	19
31	До складу реалізованого Workflow входять такі ета...	69%	33
32	Це дозволяє забезпечити ефективний контроль доступ...	69%	13
33	Будь-яка спроба видалення або модифікації журналів...	69%	17
34	Зменшення MTTR дозволяє швидше локалізувати атаку...	65%	13
35	Підключення сервісу Office 365 Outlook потребує д...	65%	16
36	Такі атаки часто супроводжуються великою кількіст...	65%	23
37	Основними перевагами Wazuh є: - відкритий вихід...	64%	21
38	Під час тестування виконувалися такі перевірки: ...	64%	40
39	Для зменшення ризиків реалізовано такі механізми ...	63%	41
40	Показано, що запропонована система має практичну ...	62%	21
41	Основними причинами такого вибору стали: - вико...	62%	57
42	Available: https://learn.microsoft.com/en-us/azur...	60%	2
43	[Online]. Available: https://learn.microsoft.com/...	60%	3
44	Available: https://learn.microsoft.com/en-us/secu...	59%	4

45	Azure Storage автоматично заблокував виконання цієї...	59%	13
46	116 БІБЛІОГРАФІЯ 1. Microsoft, Azu...	58%	8
47	[Online]. Available: https://learn.microsoft.com/...	58%	3
48	"Проектування та реалізація безпечної хмарної інф...	58%	68
49	[Online]. Available: https://csrc.nist.gov/public...	58%	3
50	Наявність єдиного сховища журналів забезпечує можл...	56%	46
51	Окрему подяку висловлюю моїй навчальній групі, з ...	55%	37

"Проектування та реалізація безпечної хмарної інфраструктури з Infrastructure as Code, IAM, централізованим логуванням та виявленням інцидентів"

Автор: Євген Смоляров

Пояснювальна записка до дипломної роботи, подана до Neoversity на здобуття ступеня Master of Science in Computer Science

червень, 2026

Студентський номер: 4294972910

Науковий керівник: проф. Дмитро Агеєв

Дата подання: 26.06.2026

© Пояснювальна записка до дипломної роботи Євгена Смолярова затверджена й відповідає вимогам щодо якості та оформлення для електронної публікації.

2

СЕРТИФІКАЦІЯ ПОЯСНЮВАЛЬНОЇ ЗАПИСКИ ДО ДИПЛОМНОЇ РОБОТИ

Я підтверджую, що я аналізував цей проєкт і, на мою думку, він відповідає належним стандартам академічної презентації. Я вважаю, що він задовільно відповідає критеріям як з точки зору якості, так і з точки зору обсягу, щоб слугувати пояснювальною запискою до дипломної роботи для здобуття наукового ступеня Master of Science in Computer Science.

Ця пояснювальна записка до дипломної роботи була подана до Neoversity та вважається достатньою для виконання передумов для здобуття наукового ступеня Master of Science in Computer Science.

проф. Дмитро Агеєв

Я підтверджую, що ця пояснювальна записка до дипломної роботи, подана на виконання вимог для здобуття ступеня Master of Science in Computer Science, виконана мною з квітень 2026 до липень 2026, є результатом моєї особистої роботи. Будь-який внесок із зовнішніх джерел або окремих осіб, зокрема використання інструментів штучного інтелекту, належним чином підтверджено шляхом цитування. Крім того, я підтверджую, що цей матеріал не був раніше поданий, повністю або частково, для здобуття наукового ступеня в цій або будь-якій іншій установі.

Роблячи цю заяву, я визнаю й розумію, що будь-яке порушення цього положення є

академічним проступком й може призвести до відрахування з програми та/або позбавлення права на здобуття наукового ступеня.

Ім'я кандидата Євген Смоляров
Підпис кандидата Дата: 26 червня 2026

6 ПОДЯКИ

Насамперед висловлюю щиру подяку Господу Богу за Його благословення, милість і вірність упродовж усього періоду навчання. Дякую за можливість навчатися в Neoversity університеті GoIT, за мудрість, знання, натхнення, підтримку та силу долати труднощі на цьому шляху. Саме Божа допомога й опіка були для мене джерелом впевненості та натхнення під час роботи над цією магістерською роботою.

Щиро дякую Антоніні Сич за те, що свого часу порекомендувала мені Neoversity та магістерську програму. Її порада стала важливим кроком, який визначив мій подальший професійний розвиток.

Висловлюю особливу вдячність моїй родині. Щиро дякую моїй мамі за фінансову підтримку, без якої навчання було б значно складнішим. Дякую мамі та сестрі за постійну віру в мене, підтримку, терпіння та слова підбадьорення протягом усього періоду навчання.

Щиро вдячний ректору Neoversity та CEO GoIT Global Антону Чорному, а також усій команді GoIT і Neoversity — викладачам, менторам, менеджерам та всім співробітникам університету — за створення сучасної освітньої екосистеми, високий рівень навчання та підтримку студентів.

Окрему подяку висловлюю моїй навчальній групі, з якою ми разом пройшли цей непростий, але надзвичайно цінний шлях. Особливо хочу подякувати Безуглого Сергія, Смоляка Сергія, Дмитра Воротинцева та Андрія Петрішіна за їхню небайдужість, підтримку та допомогу під час навчання. У найскладніші моменти вони своєчасно прийшли на допомогу, і їхня підтримка стала для мене надзвичайно важливою.

Особливу вдячність висловлюю моєму науковому керівнику, професору Дмитру Агєєву, за професійне керівництво, цінні поради, терпіння, мудрі настанови та підтримку під час виконання магістерської роботи. Його досвід, вимогливість і конструктивні рекомендації допомогли покращити якість дослідження та успішно завершити цей проєкт.

Щиро дякую всім, хто був поруч, підтримував мене, вірив у мене та своєю допомогою, порадами чи добрим словом зробив внесок у завершення цієї магістерської роботи.

7 ЗМІСТ

СПИСОК ТАБЛИЦЬ.....	10
СПИСОК РИСУНКІВ.....	12
СПИСОК СКОРОЧЕНЬ.....	15
АНОТАЦІЯ.....	16
ВСТУП.....	17
РОЗДІЛ 1.АНАЛІЗ ПРЕДМЕТНОЇ ОБЛАСТІ ТА ПОСТАНОВКА ЗАДАЧІ.....	21

1.1. Сучасні виклики безпеки хмарних середовищ.....	21
1.2. Аналіз загроз у Microsoft Azure.....	22
1.3. Аналіз методів управління доступом у хмарних системах.....	23
1.4. Аналіз систем централізованого логування.....	24
1.5. Порівняльний аналіз SIEM-рішень.....	26
1.5.1. Microsoft Sentinel	26
1.5.2. Splunk	27
1.5.3. Wazuh	27
1.5.4. MITRE ATT&CK як основа побудови правил виявлення атак	28
1.6. Аналіз підходів Infrastructure as Code	30
1.7. Аналіз сучасних підходів до автоматизованого реагування на інциденти	32
1.8. Постановка задачі дипломного проєкту	34
Висновки до першого розділу.....	38
РОЗДІЛ 2. ПРОЄКТУВАННЯ БЕЗПЕЧНОЇ ХМАРНОЇ АРХІТЕКТУРИ	39
2.1. Вимоги до системи	39
2.2. Вибір Microsoft Azure як платформи реалізації	40
2.3. Загальна архітектура рішення	41
2.4. Архітектура MVP	42
2.5. Data Flow Diagram (DFD)	44
2.6. Модель загроз STRIDE	46
2.7. Аналіз поверхні атаки	47
2.8. Аналіз довірених та недовірених компонентів	48
2.9. Архітектурні рішення щодо захисту журналів подій	49
2.10. Проєктування механізму автоматизованого реагування	50
Висновки до другого розділу	51
РОЗДІЛ 3. РЕАЛІЗАЦІЯ СИСТЕМИ	53

8	
3.1. Створення інфраструктури за допомогою Terraform	53
3.2. Налаштування Azure Entra ID	56
3.3. Реалізація моделі Role-Based Access Control (RBAC)	57
3.4. Налаштування Azure Monitor	59
3.4.1 Встановлення Azure Monitor Agent	59
3.4.2 Створення Data Collection Rule	60
3.4.3 Перевірка передачі телеметрії	61
3.5. Розгортання Log Analytics Workspace	62
3.6. Інтеграція Microsoft Sentinel	65
3.7. Налаштування збору та централізації логів	72
3.8. Реалізація Azure Storage Immutability Policy	74
3.8.1 Створення Azure Storage Account	75
3.8.2 Налаштування Immutability Policy	76
3.9. Створення правил виявлення інцидентів	77
3.9.1 Створення аналітичного правила Microsoft Sentinel	77
3.9.2 Реалізація KQL-запиту	81
3.9.3 Відповідність MITRE ATT&CK	82
3.9.4 Налаштування Entity Mapping	82
3.10. Реалізація автоматизованого реагування через Azure Logic Apps.....	83
3.11. Реалізація сповіщень про інциденти.....	85
Висновки до третього розділу.....	87
РОЗДІЛ 4. ТЕСТУВАННЯ ТА ОЦІНКА ЕФЕКТИВНОСТІ	89
4.1. Методика тестування	89
4.2. Перевірка механізмів автентифікації та авторизації	91
4.3. Тестування централізованого логування	93
4.4. Перевірка цілісності журналів подій	97
4.5. Симуляція атак та підозрілої активності	99
4.6. Перевірка роботи Detection Rules	102
4.7. Перевірка роботи Microsoft Sentinel	104
4.8. Перевірка автоматизованого реагування	107
4.9. Порівняльна оцінка запропонованого рішення	110
4.10. Аналіз отриманих результатів	111
4.11. Етичні та правові аспекти дослідження	111
Висновки до четвертого розділу.....	112
РОЗДІЛ 5. ЕКОНОМІЧНЕ ТА ПРАКТИЧНЕ ОБҐРУНТУВАННЯ	114

5.1.Оцінка вартості реалізації рішення	114
5.2. Аналіз економічної ефективності використання Azure Free Tier	115
5.3.Практична цінність та сфери застосування	116
5.4. Можливості масштабування та подальшого розвитку	118
Висновки до п'ятого розділу.....	119
ЗАГАЛЬНІ ВИСНОВКИ.....	120
БІБЛІОГРАФІЯ.....	122
ДОДАТКИ.....	125
ДОДАТОК А. Terraform Configuration Files	125
ДОДАТОК Б. Data Flow Diagram	127
ДОДАТОК В. STRIDE Threat Model	129
ДОДАТОК Г. Detection Rules	131
ДОДАТОК Д. Azure Logic Apps Workflows	135
ДОДАТОК Е. Результати тестування	135
ДОДАТОК Ж. Скриншоти реалізованої системи	135

10

СПИСОК ТАБЛИЦЬ

Таблиця № Назва Сторінка

1.1 Порівняльний аналіз SIEM-рішень	28
1.2 Техніка T1110 та її підтехніки	29
2.1 Вибір технологій для реалізації системи	41
2.2 Аналіз загроз за методологією STRIDE	46
2.3 Аналіз поверхні атаки	48
3.1 Ресурси, створені за допомогою Terraform	53
3.2 Використані ролі Azure RBAC	58
3.3 Основні параметри політики незмінності Azure Blob Storage	77
3.4 Основні параметри правила виявлення інцидентів	78
3.5 Відповідність MITRE ATT&CK	82
3.6 Entity Mapping	82
3.7 Основні параметри Azure Logic Apps	83
3.8 Стан реалізації основних компонентів розробленої системи	87
4.1 Програма тестування реалізованої системи	90
4.2 Результати тестування централізованого логування	96
4.3 Результати перевірки механізму Immutability Policy	98
4.4 Результати симуляції атаки	101
4.5 Результати перевірки Detection Rule	103
4.6 Відповідність Detection Rule матриці MITRE ATT&CK	104
4.7 Результати перевірки Microsoft Sentinel	106
4.8 Класифікація інциденту за MITRE ATT&CK	107
4.9 Результати перевірки автоматизованого реагування	109
4.10 Порівняння запропонованого рішення з традиційним підходом	110
5.1 Орієнтовна вартість компонентів рішення	114

11

Таблиця № Назва Сторінка

5.2 Сервіси Azure Free Tier, використані під час реалізації MVP	115
5.3 Перспективи розвитку системи	118

12

СПИСОК РИСУНКІВ

Рисунок № Назва Сторінка

1.1 Основні компоненти системи	37
2.1 Архітектура MVP безпечної хмарної інфраструктури	43
2.2 Data Flow Diagram безпечної хмарної інфраструктури	45

2.3 STRIDE-модель загроз для безпечної хмарної інфраструктури	47
2.4 Архітектура захисту журналів подій за допомогою Azure Storage Immutability	50
2.5 Механізм автоматизованого реагування на інциденти безпеки	51
3.1 Структура Terraform-проекту та конфігураційні файли	54
3.2 Успішне виконання Terraform Apply та створення ресурсів Azure	55
3.3 План створення ресурсів Azure за допомогою Terraform	56
3.4 Огляд середовища Microsoft Entra ID	57
3.5 Налаштування ролей доступу за допомогою Azure RBAC	58
3.6 Azure Monitor Agent, встановлений на віртуальній машині vm-thesis для передачі системних журналів до Azure Monitor та Log Analytics Workspace	60
3.7 Створене правило Data Collection Rule для збору Syslog-подій із віртуальної машини vm-thesis.	61
3.8 Створена робоча область Log Analytics Workspace law-thesis-soc-us2	63
3.9 Heartbeat-події в Log Analytics Workspace	64
3.10 Журнали Syslog у Log Analytics Workspace	65
3.11 Підключення Microsoft Sentinel до Log Analytics Workspace	67
3.12 Аналіз Syslog-подій у Microsoft Sentinel	68
3.13 Аналітичне правило Microsoft Sentinel «Multiple Failed SSH Logins	69
3.14 Налаштування Entity Mapping	70

13

Рисунок № Назва Сторінка

3.15 Інцидент безпеки «Multiple Failed SSH Logins», автоматично сформований Microsoft Sentinel	71
3.16 Записи Heartbeat у Log Analytics Workspace, що підтверджують успішну передачу телеметрії від віртуальної машини vm-thesis	72
3.17 Системні журнали Syslog, отримані від віртуальної машини vm-thesis у Log Analytics Workspace	73
3.18 Журнали автентифікації SSH, отримані із Syslog та використані для подальшого аналізу в Microsoft Sentinel	74
3.19 Контейнер securitylogs у сховищі Azure Blob Storage, призначений для зберігання журналів подій	75
3.20 Налаштування Azure Blob Immutability Policy для контейнера securitylogs	76
3.21 Microsoft Sentinel. Аналітичне правило "Multiple Failed SSH Logins" для автоматичного виявлення множинних невдалих SSH-автентифікацій	79
3.22 Результати виконання аналітичного правила "Multiple Failed SSH Logins" у Microsoft Sentinel	80
3.23 Інцидент безпеки "Multiple Failed SSH Logins", автоматично створений Microsoft Sentinel після спрацювання аналітичного прави	81
3.24 Azure Logic App, створений для автоматизованого реагування на інциденти Microsoft Sentinel	

84	
3.25	Структура Workflow Azure Logic Apps із тригером Microsoft Sentinel та дією надсилання повідомлення
85	
3.26	Робочий процес Azure Logic Apps із дією надсилання email-повідомлення про інцидент безпеки
86	
4.1	Призначення ролі користувачу в Microsoft Entra ID (RBAC) 92
4.2	Журнал активності Azure із записами про операції автентифікації та керування ресурсами
93	
4.3	Записи Heartbeat у Log Analytics Workspace, що підтверджують успішну передачу телеметрії від віртуальної машини vm-thesis
94	
4.4	Системні журнали Syslog, отримані від віртуальної машини vm-thesis у Log Analytics Workspace
95	
14	
4.5	Журнали автентифікації SSH, отримані із Syslog та використані для подальшого аналізу в Microsoft Sentinel
96	
	Рисунок № Назва Сторінка
4.6	Політика Time-based Immutability, до контейнера securitylogs 97
4.7	Контейнер securitylogs із тестовим файлом журналу подій 98
4.8	Журнали багаторазових невдалих SSH-автентифікацій, отримані у Log Analytics Workspace
100	
4.9	Результати виконання KQL-запиту для виявлення багаторазових невдалих SSH-автентифікацій
101	
4.10	Аналітичне правило "Multiple Failed SSH Logins" у Microsoft Sentinel
102	
4.11	Інцидент безпеки, автоматично створений Microsoft Sentinel після спрацювання аналітичного правила Multiple Failed SSH Logins
103	
4.12	Спрацювання аналітичного правила Multiple Failed SSH Logins у Microsoft Sentinel
105	
4.13	Інцидент безпеки Multiple Failed SSH Logins, автоматично створений Microsoft Sentinel
106	
4.14	Робочий процес Azure Logic Apps для автоматизованого реагування на інциденти Microsoft Sentinel
108	
4.15	Налаштування дії Send an Email (V2) у Azure Logic Apps 109
5.1	Архітектура реалізованого MVP-рішення із використанням сервісів Microsoft Azure
117	

15

СПИСОК СКОРОЧЕНЬ

Скорочення	Повна назва
AMA	Azure Monitor Agent
API	Application Programming Interface
Azure RBAC	Azure Role-Based Access Control
DCR	Data Collection Rule
IAM	Identity and Access Management

laC Infrastructure as Code
IP Internet Protocol
JSON JavaScript Object Notation
KQL Kusto Query Language
MFA Multi-Factor Authentication
MVP Minimum Viable Product
NSG Network Security Group
PoLP Principle of Least Privilege
RBAC Role-Based Access Control
SIEM Security Information and Event Management
SOC Security Operations Center
SSH Secure Shell
Syslog System Logging Protocol
VM Virtual Machine
WORM Write Once Read Many

16

АНОТАЦІЯ

Магістерська робота присвячена розробці та дослідженню системи моніторингу подій інформаційної безпеки на основі хмарних сервісів Microsoft Azure із використанням засобів автоматизації реагування на інциденти. Актуальність теми зумовлена зростанням кількості кіберзагроз, необхідністю своєчасного виявлення атак, централізованого збору журналів подій та забезпечення їхньої цілісності в сучасних інформаційних системах.

Метою роботи є розробка та практична реалізація архітектури системи моніторингу інформаційної безпеки із застосуванням Microsoft Sentinel, Azure Monitor, Log Analytics Workspace, Azure Storage та Azure Logic Apps, а також оцінка ефективності запропонованого рішення.

У процесі дослідження використано методи аналізу наукових джерел, моделювання архітектури інформаційної системи, технології Infrastructure as Code із використанням Terraform, засоби централізованого логування, методи виявлення інцидентів на основі KQL-запитів, а також практичне тестування механізмів автентифікації, авторизації, зберігання журналів подій та автоматизованого реагування на інциденти.

У результаті роботи розроблено та реалізовано прототип системи моніторингу інформаційної безпеки в середовищі Microsoft Azure. Виконано налаштування централізованого збору журналів подій із Linux-віртуальної машини, реалізовано їх аналіз у Microsoft Sentinel, створено аналітичні правила для виявлення багаторазових невдалих SSH-автентифікацій, налаштовано політику незмінності журналів (Time-based Immutability) у Azure Storage та реалізовано автоматизоване реагування за допомогою Azure Logic Apps. Проведено тестування всіх основних компонентів системи та оцінено ефективність запропонованого рішення.

Практичне значення роботи полягає у створенні працездатного прототипу системи моніторингу інформаційної безпеки, який може бути використаний як основа для побудови корпоративних SOC-рішень, навчальних лабораторій та подальшого розвитку комплексних систем кіберзахисту на платформі Microsoft Azure.

Ключові слова: інформаційна безпека, Microsoft Azure, Microsoft Sentinel, Log Analytics Workspace, Azure Monitor, Azure Logic Apps, Terraform.

17

ВСТУП

Актуальність теми

Стрімкий розвиток хмарних технологій суттєво змінив підходи до проектування, розгортання та експлуатації інформаційних систем. Організації все частіше переносять критично важливі сервіси до хмарних середовищ, що забезпечує масштабованість, гнучкість та зменшення витрат на підтримку власної інфраструктури. Однією з найпоширеніших платформ для побудови сучасних хмарних рішень є Microsoft Azure. [1], [2], [3], [4]

Разом із перевагами хмарних технологій зростає кількість ризиків інформаційної безпеки. Серед найбільш поширених загроз можна виділити несанкціонований доступ до ресурсів, компрометацію облікових записів, помилки конфігурації хмарної інфраструктури, відсутність централізованого моніторингу подій безпеки, а також неможливість своєчасного виявлення та реагування на інциденти.[1], [5], [6], [7]

За даними провідних міжнародних організацій у сфері кібербезпеки, значна частина інцидентів пов'язана не з вразливостями програмного забезпечення, а з помилками адміністрування, надмірними привілеями користувачів, відсутністю належного журналювання подій та недостатнім контролем доступу. У зв'язку з цим особливого значення набуває впровадження концепцій Infrastructure as Code (IaC), Identity and Access Management (IAM), централізованого логуювання, систем виявлення загроз та автоматизованого реагування на інциденти.[8], [9], [10]

Одним із перспективних підходів до побудови безпечної хмарної інфраструктури є поєднання сервісів Microsoft Azure, Microsoft Sentinel, Azure Monitor, Log Analytics Workspace, Azure Entra ID та Terraform. Така архітектура дозволяє реалізувати принцип найменших привілеїв, забезпечити централізований збір телеметрії, автоматизувати контроль конфігурацій та підвищити ефективність виявлення потенційних атак.[9], [10]

У зв'язку з цим тема проектування та реалізації безпечної хмарної інфраструктури з використанням Infrastructure as Code, централізованого логуювання, виявлення інцидентів та автоматизованого реагування є актуальною та має значну практичну цінність для сучасних організацій.[8], [9], [10], [7]

18

Мета роботи

Метою дипломної роботи є проектування та реалізація безпечної хмарної інфраструктури в середовищі Microsoft Azure із використанням технологій Infrastructure as Code, централізованого логуювання, контролю доступу, виявлення інцидентів безпеки та автоматизованого реагування на них.[8], [9], [10], [7]

Завдання дослідження

Для досягнення поставленої мети необхідно виконати такі завдання:

1. Проаналізувати сучасні загрози безпеки хмарних середовищ.
2. Дослідити можливості платформи Microsoft Azure для побудови безпечної інфраструктури.[4], [13], [14], [15]
3. Провести аналіз підходів до управління доступом у хмарних системах.[4], [13], [14], [15]
4. Виконати порівняльний аналіз сучасних SIEM-рішень.
5. Дослідити можливості використання Infrastructure as Code для автоматизації розгортання інфраструктури. [8], [9], [10], [2]
6. Спроектувати архітектуру MVP безпечної хмарної інфраструктури. [4], [13], [14], [15]
7. Реалізувати інфраструктуру за допомогою сервісів Microsoft Azure. [4], [13], [14], [15]
8. Налаштувати централізований збір та зберігання журналів подій. [1], [2], [3]
9. Інтегрувати Microsoft Sentinel для виявлення інцидентів безпеки. [16], [7], [17], [18]
10. Реалізувати механізми автоматизованого реагування на інциденти. [7], [17], [18], [19]
11. Провести тестування системи шляхом моделювання контрольованих сценаріїв атак.
12. Оцінити ефективність реалізованих механізмів захисту.

Об'єкт дослідження

Об'єктом дослідження є процес забезпечення безпеки хмарної інфраструктури в середовищі Microsoft Azure.[4], [13], [14], [15]

Предмет дослідження

Предметом дослідження є методи та засоби побудови безпечної хмарної інфраструктури із застосуванням Infrastructure as Code, механізмів управління доступом, централізованого логування, систем виявлення загроз та автоматизованого реагування на інциденти.[48, [9], [10], [7]

Методи дослідження

У роботі використовуються методи системного аналізу, моделювання архітектури інформаційних систем, аналізу ризиків інформаційної безпеки, моделювання загроз (Threat Modeling), порівняльного аналізу технологічних рішень, практичного експерименту та тестування безпекових механізмів у хмарному середовищі.[1], [2], [3], [4]

Наукова новизна

Наукова новизна роботи полягає у дослідженні та практичній реалізації комплексного підходу до забезпечення безпеки хмарної інфраструктури шляхом інтеграції технологій Infrastructure as Code, централізованого логування, SIEM-моніторингу та автоматизованого реагування в єдиному середовищі Microsoft Azure.[8], [9], [10], [1]

Практична цінність роботи

Практична цінність роботи полягає у створенні працездатного прототипу безпечної хмарної інфраструктури, який може бути використаний як навчальний стенд для підготовки фахівців із кібербезпеки, а також як базова архітектура для побудови систем моніторингу та захисту інформаційних ресурсів у хмарних середовищах.[1], [5], [6], [4]

Результати роботи можуть бути використані для демонстрації практичного впровадження принципів Zero Trust, Least Privilege, централізованого логування, Security Monitoring та Security Incident Response у хмарних інфраструктурах Microsoft Azure.[12], [29], [20], [7]

Отримані результати можуть бути використані як основа для побудови Security Operations Center (SOC) малого або середнього масштабу.[12], [29], [3],

20

Апробація результатів роботи здійснювалася шляхом тестування створеного MVP у середовищі Microsoft Azure з використанням контрольованих сценаріїв безпеки, зокрема моделювання невдалих SSH-авторизацій та перевірки захисту журналів подій за допомогою механізму Immutability Policy. [21], [22], [23], [1]

Структура роботи

Пояснювальна записка складається зі вступу, п'яти розділів, висновків, списку використаних джерел та додатків.

У першому розділі виконано аналіз предметної області, сучасних загроз хмарної безпеки, систем централізованого логування, SIEM-рішень та підходів Infrastructure as Code. [8], [9], [10], [16]

У другому розділі розглянуто проєктування архітектури безпечної хмарної інфраструктури, побудову моделі загроз STRIDE та обґрунтування архітектурних рішень. [4], [13], [14], [15]

У третьому розділі наведено практичну реалізацію системи на базі Microsoft Azure із використанням Azure Entra ID, Azure Monitor, Log Analytics Workspace, Microsoft Sentinel, Terraform та Azure Logic Apps.[8], [9], [10], [1]

У четвертому розділі представлено результати тестування, моделювання атак та оцінювання ефективності реалізованих механізмів захисту.

У п'ятому розділі наведено економічне та практичне обґрунтування запропонованого рішення. [24], [25], [6], [26]

21

РОЗДІЛ 1. АНАЛІЗ ПРЕДМЕТНОЇ ОБЛАСТІ ТА ПОСТАНОВКА ЗАДАЧІ

1.1 Сучасні виклики безпеки хмарних середовищ

Останніми роками хмарні технології стали основою цифрової трансформації організацій різних галузей. Використання хмарних платформ дозволяє забезпечити масштабованість, високу доступність сервісів, гнучке управління ресурсами та скорочення витрат на підтримку власної інфраструктури. Одними з найбільш поширених хмарних платформ є Microsoft Azure, Amazon Web Services (AWS) та Google Cloud Platform (GCP). Разом із перевагами хмарних технологій зростає кількість загроз інформаційній безпеці. На відміну від традиційних локальних середовищ, хмарна інфраструктура характеризується високою динамічністю, великою кількістю сервісів та складною моделлю розподілу відповідальності між постачальником хмарних послуг і замовником. [1], [2], [3], [4] Згідно з моделлю Shared Responsibility Model, постачальник хмарної платформи відповідає за безпеку фізичної інфраструктури, мережевого обладнання та базових сервісів, тоді як клієнт відповідає за конфігурацію ресурсів, управління доступом, захист даних та моніторинг подій безпеки.

Однією з найпоширеніших причин успішних атак на хмарні середовища є помилки конфігурації. До таких помилок належать надмірно відкриті мережеві порти, використання слабких механізмів автентифікації, відсутність багатофакторної автентифікації, надлишкові права доступу та недостатній контроль за змінами конфігурацій.

Особливу небезпеку становлять атаки на механізми автентифікації користувачів. До таких атак належать brute-force атаки, password spraying, credential stuffing та компрометація облікових записів. У випадку успішного отримання доступу зловмисник може здійснювати подальше горизонтальне або вертикальне переміщення всередині інфраструктури та отримувати доступ до критичних ресурсів.

Ще однією важливою проблемою є недостатня видимість подій безпеки. У сучасних хмарних середовищах журнали подій формуються різними сервісами та компонентами інфраструктури. За відсутності централізованого збору та аналізу журналів значно ускладнюється виявлення інцидентів та проведення розслідувань.

Для вирішення зазначених проблем сучасні організації впроваджують комплексний підхід до забезпечення хмарної безпеки, який включає централізоване логування, системи

22

моніторингу подій безпеки, автоматизацію розгортання інфраструктури за допомогою Infrastructure as Code, контроль доступу на основі ролей та використання SIEM-платформ для виявлення загроз. [8], [9], [10], [1]

У межах даної дипломної роботи зазначені підходи реалізуються на базі сервісів Microsoft Azure, що дозволяє створити практичний стенд для дослідження сучасних механізмів захисту хмарної інфраструктури та оцінювання їхньої ефективності.

1.2 Аналіз загроз у Microsoft Azure

Хмарна платформа Microsoft Azure надає широкий набір сервісів для створення, розгортання та супроводу інформаційних систем. Разом із перевагами хмарних технологій виникають нові ризики та загрози інформаційній безпеці, які потребують постійного контролю та впровадження відповідних механізмів захисту. [1], [2], [3], [4]

Однією з найпоширеніших загроз для середовищ Microsoft Azure є компрометація облікових записів користувачів. Зловмисники можуть використовувати атаки типу brute force, password spraying, credential stuffing та фішинг для отримання доступу до облікових даних. У разі успішної компрометації облікового запису атакуючий може отримати доступ до хмарних ресурсів, змінювати конфігурації або отримувати конфіденційну інформацію.

Суттєву небезпеку становлять помилки конфігурації (Misconfiguration). У багатьох випадках причиною інцидентів безпеки є неправильне налаштування ресурсів Azure. До найбільш поширених помилок належать надмірно відкриті мережеві порти, неправильні налаштування Network Security Groups (NSG), відсутність багатофакторної автентифікації та надмірні привілеї користувачів.

Ще одним важливим джерелом ризику є внутрішні загрози (Insider Threats). Працівники організації або користувачі з привілейованим доступом можуть випадково або навмисно виконувати дії, що призводять до порушення конфіденційності, цілісності або доступності інформації. У таких випадках особливого значення набувають механізми аудиту, журналювання та контролю доступу.

Окрему проблему становлять спроби приховування слідів атак. Після отримання доступу до системи зловмисники часто намагаються видалити або змінити журнали подій для ускладнення розслідування інцидентів. Тому забезпечення цілісності журналів та їх захищеного зберігання є важливим елементом сучасних систем моніторингу безпеки. Крім того, складність сучасних хмарних середовищ призводить до зростання обсягів телеметрії та журналів подій. За відсутності централізованого моніторингу значно

ускладнюється виявлення підозрілої активності та своєчасне реагування на інциденти безпеки.

23

Для мінімізації зазначених ризиків сучасні організації використовують комплексний підхід до забезпечення безпеки, який включає централізоване управління доступом, багатофакторну автентифікацію, Infrastructure as Code, централізоване логування, SIEM-платформи та механізми автоматизованого реагування.

Таким чином, проведений аналіз показав, що найбільш актуальними загрозами для середовищ Microsoft Azure є компрометація облікових записів, помилки конфігурації, внутрішні загрози, недостатня видимість подій безпеки та спроби приховування слідів атак. Для протидії зазначеним загрозам необхідне впровадження комплексної системи моніторингу, контролю доступу та автоматизованого реагування на інциденти. [1], [5], [6], [7]

1.3 Аналіз методів управління доступом у хмарних системах

У сучасних інформаційних системах управління цифровими ідентичностями та правами доступу є одним із ключових компонентів кібербезпеки. Зі зростанням кількості хмарних сервісів і користувачів значно ускладнюється контроль доступу до ресурсів, що підвищує ризик несанкціонованого використання облікових записів та компрометації даних. [27], [21], [28], [4]

Identity and Access Management (IAM) являє собою сукупність політик, процесів і технологій, які забезпечують ідентифікацію користувачів, перевірку їхньої автентичності та контроль доступу до інформаційних ресурсів відповідно до встановлених правил безпеки.

Основними завданнями IAM є:

- централізоване управління обліковими записами;
- контроль автентифікації користувачів;
- управління дозволами та ролями;
- аудит дій користувачів;
- реалізація принципу найменших привілеїв;
- підтримка багатофакторної автентифікації.

У хмарних середовищах одним із найпоширеніших підходів до управління доступом є Role-Based Access Control (RBAC). Дана модель передбачає призначення прав доступу не безпосередньо користувачам, а ролям. Користувач отримує доступ до ресурсів відповідно до ролі, яка йому призначена.

Перевагами RBAC є:

- спрощення адміністрування доступу;
- меншення ризику надмірних привілеїв;
- підвищення керованості безпекою;

24

- покращення відповідності вимогам аудиту та комплаєнсу.

Важливим принципом сучасних IAM-систем є Principle of Least Privilege (PoLP), відповідно до якого користувач або сервіс повинні мати лише ті права, які необхідні для виконання їхніх функцій. Реалізація цього принципу дозволяє зменшити потенційні наслідки компрометації облікового запису та обмежити можливості зломисника у разі отримання доступу до системи.

Останніми роками широкого поширення набула концепція Zero Trust Architecture.

Даний підхід базується на принципі «ніколи не довіряй, завжди перевіряй» (Never Trust, Always Verify). У межах цієї моделі кожен запит на доступ до ресурсу повинен проходити перевірку незалежно від розташування користувача чи пристрою.

У середовищі Microsoft Azure реалізація функцій IAM здійснюється за допомогою сервісу Microsoft Entra ID. Платформа забезпечує централізоване управління користувачами, групами, ролями та механізмами автентифікації. Додатково Entra ID підтримує інтеграцію з багатофакторною автентифікацією (MFA), умовним доступом (Conditional Access) та механізмами моніторингу активності користувачів.

У межах даного дипломного проєкту Microsoft Entra ID використовується як центральний компонент керування доступом до ресурсів хмарної інфраструктури. Для реалізації безпечної моделі доступу застосовуються принципи RBAC та Least Privilege, що дозволяє мінімізувати ризики несанкціонованого доступу до критичних компонентів системи. [27], [12], [28], [29]

1.4 Аналіз систем централізованого логування

Одним із ключових елементів сучасної системи кібербезпеки є централізований збір та аналіз журналів подій. У складних хмарних середовищах інформація про події безпеки

генерується великою кількістю компонентів, включаючи віртуальні машини, мережеві пристрої, сервіси автентифікації, засоби моніторингу та прикладні системи. [27], [12], [28], [1] За відсутності централізованого логування журнали подій зберігаються локально на окремих вузлах інфраструктури. Такий підхід ускладнює виявлення інцидентів, проведення розслідувань та аналіз ланцюгів атак. Крім того, локальні журнали можуть бути видалені або змінені зловмисником після компрометації системи.

Централізоване логування передбачає збір журналів з різних джерел у єдине сховище, де вони можуть бути проаналізовані автоматизованими засобами моніторингу. Даний підхід забезпечує:

- централізоване зберігання подій;

25

- підвищення видимості інфраструктури;
- прощення пошуку інцидентів;
- підтримку аудиту та розслідувань;
- виявлення підозрілої активності;
- підготовку звітності щодо безпеки.

Особливого значення централізоване логування набуває у хмарних середовищах, де ресурси можуть створюватися та видалятися автоматично. У таких умовах журнал подій часто є єдиним джерелом інформації про дії користувачів та зміни конфігурацій.

Для ефективного моніторингу недостатньо лише збирати журнали подій. Необхідно також виконувати їх кореляцію, аналіз та автоматичне виявлення аномалій. Саме тому сучасні організації використовують спеціалізовані платформи моніторингу та аналізу безпеки.

У середовищі Microsoft Azure основними компонентами централізованого моніторингу є Azure Monitor та Log Analytics Workspace.

Azure Monitor забезпечує збір телеметрії, метрик та журналів подій з різних ресурсів Azure. Для передачі даних із віртуальних машин використовується Azure Monitor Agent (AMA), який є сучасним механізмом збору телеметрії та поступово замінює застарілі рішення попереднього покоління.

Передача журналів до централізованого сховища здійснюється за допомогою Data Collection Rules (DCR). Дані правила визначають джерела журналів, категорії подій та кінцеві точки доставки телеметрії.

Центральним компонентом архітектури є Log Analytics Workspace, який виконує функції сховища журналів та надає можливість виконання запитів мовою Kusto Query Language (KQL). Використання KQL дозволяє здійснювати пошук подій, кореляцію даних, виявлення аномалій та підготовку аналітичних звітів.

Для Linux-систем особливу цінність становлять журнали Syslog, які містять інформацію про роботу операційної системи, служби автентифікації, мережеві події та дії користувачів. Аналіз таких журналів дозволяє своєчасно виявляти спроби несанкціонованого доступу, атаки типу brute force та інші підозрілі події.

У межах даного дипломного проєкту реалізовано централізований збір журналів із Linux-віртуальної машини в середовищі Microsoft Azure. Передача телеметрії здійснюється через Azure Monitor Agent та Data Collection Rules до Log Analytics Workspace, де журнали стають доступними для подальшого аналізу та обробки засобами Microsoft Sentinel.

Таким чином, централізоване логування є фундаментом побудови системи моніторингу безпеки та створює основу для подальшого впровадження механізмів виявлення інцидентів і автоматизованого реагування на загрози. [1], [5], [6], [7]

26

1.5 Порівняльний аналіз SIEM-рішень

Сучасні організації генерують величезну кількість журналів подій із серверів, мережевого обладнання, хмарних сервісів, систем автентифікації та прикладних програм. Ефективний аналіз такої кількості даних неможливий без використання спеціалізованих платформ класу Security Information and Event Management (SIEM). [27], [12], [28], [16] SIEM-системи призначені для централізованого збору, зберігання, кореляції та аналізу подій безпеки. Вони дозволяють виявляти підозрілу активність, автоматизувати моніторинг, підтримувати процеси реагування на інциденти та забезпечувати відповідність вимогам інформаційної безпеки.

Основними функціями SIEM-систем є:

- централізований збір журналів подій;
- кореляція подій із різних джерел;
- автоматичне виявлення загроз;
- побудова аналітичних правил;
- підтримка розслідування інцидентів;

- формування звітності;
- інтеграція з механізмами автоматизованого реагування.

Серед найбільш популярних SIEM-рішень можна виділити Microsoft Sentinel, Splunk Enterprise Security та Wazuh.[16], [7], [17], [18]

1.5.1 Microsoft Sentinel

Microsoft Sentinel є хмарною SIEM- та SOAR-платформою, побудованою на базі сервісів Microsoft Azure. Рішення забезпечує централізований збір телеметрії, кореляцію подій безпеки, виявлення загроз та автоматизоване реагування на інциденти. [1], [5], [6], [16]

Основними перевагами Microsoft Sentinel є:

- повна інтеграція з екосистемою Microsoft Azure;
- підтримка Kusto Query Language (KQL);
- інтеграція з MITRE ATT&CK;
- автоматичне створення інцидентів;
- підтримка автоматизованого реагування через Logic Apps;
- масштабованість хмарної архітектури;
- відсутність необхідності підтримувати власну інфраструктуру SIEM.

27

Завдяки інтеграції з Azure Monitor та Log Analytics Workspace Sentinel дозволяє будувати правила виявлення атак, виконувати кореляцію подій та централізовано керувати інцидентами безпеки.

1.5.2 Splunk Enterprise Security

Splunk є одним із найвідоміших комерційних SIEM-рішень. Платформа підтримує збір та аналіз великих обсягів журналів подій, має потужні можливості пошуку та кореляції подій. [16], [7], [17], [18]

Перевагами Splunk є:

- висока продуктивність;
- розвинуті аналітичні можливості;
- велика кількість інтеграцій;
- зріла екосистема додатків.

Водночас використання Splunk часто потребує значних фінансових витрат на ліцензування та адміністрування інфраструктури.

1.5.3 Wazuh

Wazuh є безкоштовною платформою з відкритим вихідним кодом для моніторингу безпеки та виявлення загроз. Рішення підтримує збір журналів, моніторинг цілісності файлів, аналіз вразливостей та функції базового SIEM.

Основними перевагами Wazuh є:

- відкритий вихідний код;
- відсутність витрат на ліцензування;
- можливість локального розгортання;
- активна спільнота користувачів.

Недоліками Wazuh є складніше масштабування та необхідність самостійного адміністрування всієї інфраструктури.

Порівняльний аналіз SIEM-рішень надано у таблиці 1.1.

28

Таблиця 1.1 – Порівняльний аналіз SIEM-рішень
Критерій Microsoft Sentinel Splunk Enterprise Security Wazuh
Тип рішення Cloud Native Комерційне Open Source
Інтеграція з Azure Висока Середня Обмежена
Підтримка MITRE ATT&CK Так Так Частково
Автоматизоване реагування (SOAR) Так Так Обмежено
Масштабованість Висока Висока Середня
Вартість впровадження Середня Висока Низька

Підтримка KQL Так Ні Ні

Простота інтеграції з Azure Monitor Висока Середня Низька

Підтримка Logic Apps Так Через інтеграції Ні

Придатність для даного проєкту Висока Середня Середня

Обґрунтування вибору Microsoft Sentinel: у межах даного дипломного проєкту для реалізації системи моніторингу та виявлення інцидентів було обрано Microsoft Sentinel.

Основними причинами такого вибору стали:

- використання Microsoft Azure як основної хмарної платформи;
- наявність вбудованої інтеграції з Azure Monitor та Log Analytics Workspace;
- підтримка аналітичних правил на основі KQL;
- автоматичне створення Alerts та Incidents;
- можливість інтеграції з Azure Logic Apps для реалізації SOAR-функціональності;
- підтримка MITRE ATT&CK та сучасних підходів до threat detection.

Таким чином, Microsoft Sentinel найбільш повно відповідає вимогам даного дипломного проєкту та забезпечує необхідні можливості для реалізації MVP безпечної хмарної інфраструктури з централізованим моніторингом, виявленням загроз та автоматизованим реагуванням на інциденти.

1.5.4 MITRE ATT&CK як основа побудови правил виявлення атак

Ефективність сучасних систем моніторингу безпеки значною мірою залежить від правильного розуміння поведінки зловмисників та способів реалізації атак. Для стандартизації знань про тактики, техніки та процедури атакуючих широкого поширення набула база знань MITRE ATT&CK (Adversarial Tactics, Techniques and Common Knowledge).

29

MITRE ATT&CK являє собою глобальну базу знань, яка систематизує реальні методи та техніки, що використовуються кіберзлочинцями під час проведення атак. Фреймворк дозволяє організаціям будувати механізми захисту, виявлення та реагування на основі поведінкових ознак атак замість аналізу окремих сигнатур.

Структура MITRE ATT&CK базується на трьох основних рівнях:

- тактики (Tactics);
- техніки (Techniques);
- підтехніки (Sub-techniques).

Тактики описують цілі зловмисника на певному етапі атаки, тоді як техніки та підтехніки визначають конкретні способи досягнення цих цілей.

До найбільш поширених тактик MITRE ATT&CK належать:

- Initial Access;
- Execution;
- Persistence;
- Privilege Escalation;
- Defense Evasion;
- Credential Access;
- Discovery;
- Lateral Movement;
- Collection;
- Exfiltration;
- Impact.

Однією з найбільш актуальних загроз для хмарних середовищ є компрометація облікових записів шляхом підбору облікових даних. Такі атаки відносяться до тактики Credential Access та реалізуються за допомогою техніки T1110 – Brute Force, які наведені у таблиці 1.2

Таблиця 1.2 - Техніка T1110 та її підтехніки

MITRE ID Назва

T1110 Brute Force

T1110.001 Password Guessing

T1110.002 Password Cracking

T1110.003 Password Spraying

T1110.004 Credential Stuffing

30

Для Linux-серверів та SSH-служб найбільш типовою є підтехніка T1110.001 Password Guessing, під час якої зловмисник багаторазово намагається підібрати пароль до існуючого або

вигаданого облікового запису.

Такі атаки часто супроводжуються великою кількістю повідомлень типу:

- Failed password;
- Invalid user;
- Authentication failure;
- Connection closed by authenticating user.

Саме аналіз подібних подій є основою для побудови правил виявлення атак типу brute force у SIEM-системах.

У сучасних рішеннях класу SIEM фреймворк MITRE ATT&CK використовується як єдиний стандарт класифікації загроз. Це дозволяє аналітикам безпеки швидко розуміти характер атаки, оцінювати її потенційні наслідки та визначати пріоритетність реагування.

Microsoft Sentinel має вбудовану інтеграцію з MITRE ATT&CK та дозволяє

прив'язувати аналітичні правила до конкретних технік і підтехнік. Завдяки цьому кожен створений alert або incident може бути автоматично класифікований відповідно до поведінки атакуючого.

У межах даного дипломного проєкту для виявлення множинних невдалих SSH-автентифікацій було реалізовано правило Microsoft Sentinel «Multiple Failed SSH Logins».

Правило використовує аналіз системних журналів Linux та відповідає техніці MITRE ATT&CK T1110 (Brute Force), а також підтехніці T1110.001 (Password Guessing).

Під час тестування було виконано серію контрольованих невдалих SSH-підключень до віртуальної машини Microsoft Azure. На основі отриманих журналів Microsoft Sentinel успішно сформував Alert та Incident, що підтвердило працездатність механізму виявлення атак відповідно до моделі MITRE ATT&CK.

Таким чином, використання MITRE ATT&CK у межах даного проєкту дозволяє забезпечити стандартизований підхід до побудови правил виявлення загроз та підвищує якість процесів моніторингу безпеки у хмарному середовищі Microsoft Azure.

1.6 Аналіз підходів Infrastructure as Code

Розвиток хмарних технологій суттєво змінив підходи до розгортання та адміністрування IT-інфраструктури. Традиційне ручне створення ресурсів через графічні інтерфейси (ClickOps) поступово замінюється автоматизованими методами управління

31

інфраструктурою. Одним із найпоширеніших підходів є концепція Infrastructure as Code (IaC). [8], [9], [10], [1]

Infrastructure as Code являє собою практику управління та налаштування інфраструктури за допомогою програмного коду, який може зберігатися в системах контролю версій, проходити перевірку якості та автоматично виконуватися під час розгортання середовищ.

Основними перевагами використання IaC є:

- автоматизація процесу створення інфраструктури;
- забезпечення повторюваності розгортання;
- зменшення кількості людських помилок;
- контроль змін через системи версіонування;
- швидке відновлення середовища після інцидентів;
- підвищення рівня безпеки та аудиту конфігурацій.

У сучасних хмарних середовищах ручне налаштування ресурсів може призводити до виникнення конфігураційного дрейфу (Configuration Drift), коли фактичний стан інфраструктури відрізняється від початково задокументованого. Такі відхилення часто стають причиною вразливостей безпеки та порушення політик доступу.

Використання Infrastructure as Code дозволяє усунути дану проблему шляхом створення єдиного джерела істини (Single Source of Truth), яке містить повний опис інфраструктури у вигляді коду.

Одним із найбільш популярних інструментів реалізації Infrastructure as Code є Terraform компанії HashiCorp. Terraform використовує декларативний підхід до опису інфраструктури, у якому адміністратор визначає бажаний стан ресурсів, а система автоматично виконує необхідні зміни для його досягнення.

У середовищі Microsoft Azure Terraform підтримує створення та управління такими ресурсами:

- Resource Groups;
- Virtual Machines;
- Virtual Networks;
- Network Security Groups;
- Log Analytics Workspaces;
- Microsoft Sentinel;

- Azure Storage;
- Azure Monitor;
- інші сервіси платформи Azure.

32

З точки зору кібербезпеки застосування Terraform забезпечує низку додаткових переваг. По-перше, усі зміни інфраструктури документуються у репозиторії вихідного коду, що створює повний журнал аудиту. По-друге, конфігурації можуть проходити автоматичну перевірку безпеки перед застосуванням. По-третє, використання шаблонів дозволяє стандартизувати налаштування безпеки для всіх середовищ організації.

Важливим елементом безпечного використання IaC є інтеграція з процесами

DevSecOps. У даному підході перевірки безпеки виконуються автоматично на ранніх етапах життєвого циклу розробки та розгортання інфраструктури. Це дозволяє виявляти помилки конфігурації до моменту створення ресурсів у хмарному середовищі.

У межах даного дипломного проекту Terraform розглядається як основний інструмент автоматизованого розгортання компонентів безпечної хмарної інфраструктури. Використання Infrastructure as Code дозволяє забезпечити відтворюваність середовища, контроль змін та зменшення ризиків, пов'язаних із ручним адмініструванням ресурсів Azure.[8], [9], [10], [4]

1.7 Аналіз сучасних підходів до автоматизованого реагування на інциденти

У сучасних умовах кількість подій безпеки, які генеруються інформаційними системами та хмарними середовищами, постійно зростає. Згідно зі звітами провідних постачальників рішень у сфері кібербезпеки, аналітики центрів моніторингу безпеки (Security Operations Center, SOC) щоденно обробляють тисячі подій, серед яких лише незначна частина є реальними інцидентами безпеки. У таких умовах використання виключно ручних методів реагування стає неефективним та призводить до збільшення часу виявлення та усунення загроз.[1], [5], [6], [7]

Для вирішення цієї проблеми сучасні організації впроваджують підходи автоматизації процесів реагування на інциденти безпеки. Основною концепцією такого підходу є використання технологій Security Orchestration, Automation and Response (SOAR).

SOAR являє собою комплекс засобів та процесів, які забезпечують автоматизовану обробку подій безпеки, координацію роботи різних інструментів кіберзахисту та виконання типових дій реагування без участі аналітика. Використання SOAR дозволяє скоротити навантаження на персонал SOC, підвищити швидкість реагування та мінімізувати вплив людського фактору.

До основних функцій SOAR-рішень належать:

- автоматизований аналіз подій безпеки;
- кореляція інформації з різних джерел;
- автоматичне створення інцидентів;

33

- виконання сценаріїв реагування;
- надсилання сповіщень відповідальним особам;
- інтеграція із засобами моніторингу та захисту;
- документування процесу реагування.

Одним із ключових елементів SOAR є Playbooks. Playbook являє собою формалізований сценарій реагування на інцидент, який визначає послідовність дій, що виконуються після виявлення загрози. Залежно від типу інциденту Playbook може включати надсилання повідомлень, створення заявок у системах Service Desk, блокування облікових записів, ізоляцію ресурсів або виконання додаткових перевірок.

У сучасних SOC значна увага приділяється скороченню показника Mean Time To Respond (MTTR), який характеризує середній час реагування на інцидент безпеки. Зменшення MTTR дозволяє швидше локалізувати атаку та мінімізувати можливі наслідки компрометації інформаційних ресурсів.

У хмарному середовищі Microsoft Azure реалізація SOAR-функціональності здійснюється за допомогою сервісу Azure Logic Apps. Даний сервіс дозволяє створювати автоматизовані робочі процеси без необхідності розробки складного програмного коду. Logic Apps підтримує інтеграцію з Microsoft Sentinel, Microsoft Defender, електронною поштою, системами обробки заявок та іншими сервісами.

Після спрацювання аналітичного правила Microsoft Sentinel може автоматично запускати відповідний Playbook, реалізований у Azure Logic Apps. У межах такого сценарію можуть виконуватися дії з отримання додаткової інформації про інцидент, надсилання повідомлень адміністраторам безпеки або запуск інших процесів реагування.

Перевагами використання автоматизованого реагування є:

- скорочення часу реагування на інциденти;
- зменшення навантаження на аналітиків SOC;
- стандартизація процесів реагування;
- зниження ризику людських помилок;
- підвищення ефективності моніторингу безпеки;
- можливість масштабування процесів кіберзахисту.

У межах даного дипломного проєкту для реалізації автоматизованого реагування обрано Microsoft Sentinel у поєднанні з Azure Logic Apps. Такий підхід дозволяє автоматично реагувати на виявлені події безпеки та забезпечує інтеграцію між компонентами системи моніторингу й реагування.

34

Таким чином, використання підходів SOAR та автоматизованого реагування є важливою складовою сучасних систем кібербезпеки та дозволяє підвищити ефективність процесів виявлення й обробки інцидентів у хмарних середовищах. [16], [17], [18], [20]

1.8 Постановка задачі дипломного проєкту

У сучасних хмарних середовищах забезпечення інформаційної безпеки є одним із ключових викликів для організацій, які використовують сервіси публічних хмар. Збільшення кількості хмарних ресурсів, користувачів та інтегрованих сервісів призводить до зростання ризиків несанкціонованого доступу, компрометації облікових записів, помилок конфігурації та недостатньої видимості подій безпеки. [4], [13], [14], [15]

Особливої актуальності набуває проблема своєчасного виявлення атак та централізованого моніторингу подій безпеки. У багатьох випадках журнали подій розподілені між окремими сервісами, що ускладнює розслідування інцидентів та збільшує час реагування на загрози.

У межах даного дипломного проєкту розглядається задача побудови безпечної хмарної інфраструктури на платформі Microsoft Azure із використанням сучасних підходів Cloud Security, Identity and Access Management, Infrastructure as Code, централізованого логування та Security Monitoring.

Захищувані активи: до основних активів, які потребують захисту в межах проєкту, належать:

- облікові записи користувачів Microsoft Entra ID;
- ролі та політики доступу Azure RBAC;
- віртуальна машина Linux (Ubuntu);
- журнали подій безпеки;
- конфігурації хмарної інфраструктури;
- правила виявлення інцидентів;
- ресурси Microsoft Azure;
- дані моніторингу та телеметрії.

Компрометація будь-якого з перелічених активів може призвести до порушення конфіденційності, цілісності або доступності системи.

Модель потенційного зловмисника: у межах роботи розглядається зовнішній атакуючий, який має доступ до мережесервісів, опублікованих в Інтернеті, але не має початкових привілеїв у хмарному середовищі.

Передбачається, що атакуючий може:

35

- виконувати мережеве сканування;
- здійснювати спроби підбору облікових даних;
- проводити атаки типу brute force;
- аналізувати відкриті мережесервіси;
- використовувати загальнодоступні інструменти автоматизації атак.

При цьому не розглядаються сценарії фізичного доступу до інфраструктури або використання невідомих вразливостей нульового дня (Zero-Day).

Основні загрози: на основі проведеного аналізу були визначені такі ключові загрози:

1. Несанкціонований доступ до облікових записів.
2. Атаки типу Brute Force на SSH-служби.
3. Надмірні привілеї користувачів.
4. Відсутність централізованого моніторингу подій.
5. Приховування слідів атаки шляхом модифікації журналів.
6. Помилки конфігурації хмарної інфраструктури.
7. Несвоєчасне виявлення інцидентів безпеки.
8. Відсутність автоматизованого реагування на підозрілу активність.

Особлива увага в межах MVP приділяється атакам на механізми автентифікації Linux-серверів через SSH, які є одними з найбільш поширених сценаріїв компрометації серверної інфраструктури.

Безпекові властивості, що перевіряються: у межах реалізації та тестування системи перевіряються такі властивості безпеки:

Конфіденційність: забезпечується через використання механізмів автентифікації, RBAC та контроль доступу до ресурсів Microsoft Azure.

Цілісність: забезпечується шляхом контролю конфігурацій інфраструктури, використання Infrastructure as Code та механізмів захисту журналів подій від модифікації.

Доступність: забезпечується використанням хмарної інфраструктури Microsoft Azure та централізованого моніторингу стану системи.

Підзвітність (Accountability): досягається через централізований збір журналів подій та аудит дій користувачів.

Виявлення інцидентів (Detection Capability): перевіряється шляхом моделювання контрольованих атак та аналізу спрацювання правил Microsoft Sentinel.

Формулювання задачі: метою дипломного проєкту є проєктування, реалізація та тестування MVP безпечної хмарної інфраструктури на базі Microsoft Azure, яка забезпечує:

- централізоване управління доступом;
- автоматизоване розгортання інфраструктури;

36

- централізований збір журналів подій;
- захист журналів від модифікації;
- виявлення інцидентів безпеки;
- автоматизоване реагування на загрози.

Для досягнення поставленої мети необхідно реалізувати інтегровану архітектуру, яка об'єднує Microsoft Entra ID, RBAC, Terraform, Azure Monitor, Log Analytics Workspace, Microsoft Sentinel, Azure Storage Immutability Policy та Azure Logic Apps у межах єдиного безпечного хмарного середовища.

Результатом роботи має стати функціональний MVP, який демонструє практичну реалізацію сучасних підходів Cloud Security, SecOps та Defensive Security у середовищі Microsoft Azure.[4], [13], [14], [15]

37

Рисунок 1.1 – Основні компоненти системи

38

Висновки до першого розділу

У першому розділі було проведено аналіз сучасних викликів безпеки хмарних середовищ, досліджено основні загрози інформаційній безпеці в інфраструктурах Microsoft Azure та розглянуто сучасні підходи до забезпечення кіберзахисту. [4], [13], [14], [15] Встановлено, що основними ризиками для хмарних середовищ є несанкціонований доступ до ресурсів, надмірні привілеї користувачів, помилки конфігурації, відсутність централізованого моніторингу та несвоєчасне виявлення інцидентів безпеки. Особливу небезпеку становлять атаки, спрямовані на компрометацію облікових записів та отримання несанкціонованого доступу до критичних ресурсів.

У межах аналізу було розглянуто сучасні підходи до управління цифровими ідентичностями та контролю доступу. Визначено, що використання Microsoft Entra ID, Role-Based Access Control та принципу Least Privilege дозволяє суттєво зменшити ризики, пов'язані з надмірними привілеями та помилками адміністрування.

Дослідження концепції Infrastructure as Code показало, що автоматизація розгортання інфраструктури за допомогою Terraform забезпечує відтворюваність конфігурацій, контроль змін та зменшення кількості людських помилок. Використання IaC також сприяє впровадженню підходів DevSecOps та підвищує рівень керованості безпекою хмарних середовищ.

Окрему увагу було приділено питанням централізованого логування та моніторингу подій безпеки. Встановлено, що використання Azure Monitor, Log Analytics Workspace та Microsoft Sentinel дозволяє забезпечити централізований збір журналів подій, кореляцію

інформації з різних джерел та автоматизоване виявлення підозрілої активності.

У результаті порівняльного аналізу SIEM-рішень було обґрунтовано вибір Microsoft Sentinel як основної платформи моніторингу та виявлення інцидентів у межах даного дипломного проєкту. Основними факторами вибору стали інтеграція з Microsoft Azure, підтримка MITRE ATT&CK, можливість створення власних аналітичних правил та підтримка автоматизованого реагування на інциденти.

Також було сформовано модель потенційного злоумисника, визначено основні загрози та захищувані активи системи. На основі проведеного аналізу сформульовано вимоги до безпечної хмарної інфраструктури та обґрунтовано вибір архітектурних компонентів майбутнього рішення.

Отримані результати створюють теоретичну основу для подальшого проєктування архітектури системи, побудови моделі загроз STRIDE, реалізації компонентів безпеки та проведення практичного тестування у наступних розділах дипломної роботи.

39

РОЗДІЛ 2. ПРОЄКТУВАННЯ БЕЗПЕЧНОЇ ХМАРНОЇ АРХІТЕКТУРИ

2.1 Вимоги до системи

Під час проєктування безпечної хмарної інфраструктури було сформовано набір функціональних та нефункціональних вимог, які визначають архітектуру та основні можливості системи.[4], [13], [14], [15]

Функціональні вимоги: система повинна забезпечувати автоматизоване розгортання хмарної інфраструктури за допомогою підходу Infrastructure as Code. Для цього використовується інструмент Terraform, який дозволяє створювати та керувати ресурсами Microsoft Azure у вигляді програмного коду. Система повинна забезпечувати централізоване управління обліковими записами користувачів та контроль доступу до ресурсів через Microsoft Entra ID. Система повинна підтримувати рольову модель управління доступом (Role-Based Access Control, RBAC), що дозволяє надавати користувачам лише необхідні права відповідно до їхніх функціональних обов'язків. Система повинна забезпечувати централізований збір журналів подій безпеки та операційних журналів від усіх компонентів інфраструктури. Система повинна забезпечувати зберігання журналів подій у централізованому сховищі для подальшого аналізу та розслідування інцидентів інформаційної безпеки. Система повинна забезпечувати автоматичне виявлення підозрілої активності на основі правил аналізу журналів подій у Microsoft Sentinel. Система повинна підтримувати створення повідомлень про інциденти безпеки та автоматичне формування об'єктів розслідування (Incident). Система повинна забезпечувати автоматичне надсилання сповіщень про виявлені інциденти безпеки за допомогою Azure Logic Apps. Система повинна забезпечувати захист журналів подій від несанкціонованого видалення або модифікації шляхом використання політики незмінності даних (Immutability Policy).

Нефункціональні вимоги: система повинна відповідати принципу Least Privilege та надавати користувачам лише мінімально необхідний рівень доступу до ресурсів. Система повинна забезпечувати конфіденційність, цілісність та доступність даних відповідно до сучасних вимог інформаційної безпеки. Система повинна підтримувати можливість масштабування шляхом додавання нових джерел журналів подій та додаткових сервісів Microsoft Azure. Система повинна забезпечувати відтворюваність інфраструктури шляхом використання Infrastructure as Code та системи контролю версій. Система повинна забезпечувати централізований моніторинг подій безпеки в режимі, близькому до реального часу. Система повинна бути побудована на основі нативних сервісів Microsoft Azure для забезпечення максимальної сумісності та спрощення адміністрування. Система повинна підтримувати можливість інтеграції з механізмами автоматизованого реагування на інциденти та подальшого розвитку до повноцінного SOC-рішення.[7], [17], [18], [19]

40

2.2 Вибір Microsoft Azure як платформи реалізації

Для реалізації проєкту безпечної хмарної інфраструктури було обрано платформу Microsoft Azure. Вибір даної платформи обумовлений широкими можливостями у сфері хмарної безпеки, наявністю вбудованих засобів моніторингу та управління доступом, а також високим рівнем інтеграції між окремими сервісами.[1], [5], [4], [6]

Однією з ключових переваг Microsoft Azure є можливість побудови комплексної

системи захисту на базі єдиної екосистеми. У межах платформи доступні сервіси для управління ідентичностями та доступом (Microsoft Entra ID), централізованого моніторингу (Azure Monitor), збору та аналізу журналів подій (Log Analytics Workspace), виявлення інцидентів безпеки (Microsoft Sentinel), а також автоматизованого реагування на події безпеки (Azure Logic Apps).

Важливою перевагою Azure є підтримка сучасних принципів кібербезпеки, зокрема Zero Trust Architecture, Role-Based Access Control (RBAC), Multi-Factor Authentication (MFA) та принципу Least Privilege. Це дозволяє забезпечити ефективний контроль доступу до ресурсів та мінімізувати ризик несанкціонованого доступу.

Для реалізації інфраструктури як коду (Infrastructure as Code) платформа Azure має повноцінну підтримку Terraform. Це дозволяє автоматизувати процес створення та конфігурації ресурсів, забезпечити відтворюваність середовища та зменшити кількість помилок, пов'язаних із ручним адмініструванням.

Ще однією важливою перевагою є наявність Microsoft Sentinel — хмарної SIEM-платформи, яка нативно інтегрується з сервісами Azure. Sentinel забезпечує централізований аналіз подій безпеки, кореляцію журналів, створення аналітичних правил, генерацію сповіщень та автоматичне створення інцидентів безпеки. Це дозволяє реалізувати повний цикл моніторингу та виявлення загроз у межах одного середовища.

Для забезпечення цілісності журналів подій у проєкті використовується Azure Storage Account із політикою Immutability Policy. Застосування механізму WORM (Write Once Read Many) дозволяє захистити журнали від видалення або модифікації протягом визначеного періоду зберігання, що є важливим елементом цифрової криміналістики та розслідування інцидентів.

Додатковою перевагою Microsoft Azure є можливість автоматизації процесів реагування за допомогою Azure Logic Apps. Використання цього сервісу дозволяє автоматично надсилати повідомлення про інциденти безпеки, запускати сценарії реагування та інтегрувати систему з іншими сервісами без необхідності розробки власного програмного забезпечення.

Таким чином, Microsoft Azure забезпечує необхідний набір сервісів для реалізації безпечної хмарної інфраструктури, підтримує сучасні підходи Cloud Security та дозволяє реалізувати всі функціональні вимоги, визначені в межах даного проєкту. Саме тому ця платформа була обрана як основне середовище для реалізації MVP-рішення, дивися таблицю 2.1 - Вибір технологій для реалізації системи.

41

Таблиця 2.1 – Вибір технологій для реалізації системи

Критерій Microsoft Azure

IAM Microsoft Entra ID

Infrastructure as Code Terraform

Моніторинг Azure Monitor

Централізоване логування Log Analytics Workspace

SIEM Microsoft Sentinel

Захист логів Azure Storage Immutability

Автоматичне реагування Azure Logic Apps

Підтримка Zero Trust Так

Підтримка RBAC Так

2.3 Загальна архітектура рішення

Проектування архітектури системи є одним із ключових етапів створення безпечної хмарної інфраструктури. Основною метою архітектурного проектування є побудова середовища, яке забезпечує безпечне управління доступом, централізований збір журналів подій, виявлення інцидентів безпеки та автоматизоване реагування на них. [7], [17], [18], [19]

Під час проектування архітектури було обрано багаторівневий підхід, який базується на принципах Zero Trust Architecture, Least Privilege та Defense in Depth. Архітектура побудована на платформі Microsoft Azure та об'єднує сервіси управління ідентичностями, моніторингу, аналізу журналів, виявлення загроз і автоматизованого реагування.

Запропонована архітектура складається з декількох взаємопов'язаних рівнів.

Рівень управління ідентичностями та доступом: перший рівень архітектури представлений сервісом Microsoft Entra ID, який виконує функції централізованого управління користувачами, групами та механізмами автентифікації. Через Entra ID реалізуються механізми багатфакторної автентифікації (MFA), ролівого контролю доступу (RBAC) та принцип найменших привілеїв (Least Privilege). Використання централізованого управління доступом дозволяє зменшити ризики компрометації облікових записів та несанкціонованого доступу до ресурсів хмарної інфраструктури.

Рівень хмарних ресурсів: другий рівень складається з ресурсів Microsoft Azure, які формують робоче середовище системи. До складу цього рівня входять віртуальні машини, мережеві компоненти, служби зберігання даних та інші сервіси Azure. Саме на цьому рівні функціонують прикладні сервіси та генеруються події безпеки, які надалі використовуються для моніторингу та виявлення інцидентів.

Рівень збору журналів подій: для централізованого збору журналів використовується Azure Monitor. Сервіс отримує телеметрію та журнали подій від усіх підключених ресурсів Azure. Зібрані дані передаються до Log Analytics Workspace, який виконує функції централізованого сховища журналів. Це забезпечує єдину точку доступу до даних моніторингу

42

та дозволяє виконувати їх подальший аналіз за допомогою мови запитів Kusto Query Language (KQL).

Рівень виявлення інцидентів безпеки: для реалізації функцій Security Information and Event Management (SIEM) використовується Microsoft Sentinel. Даний сервіс інтегрується з Log Analytics Workspace та виконує аналіз журналів подій у режимі реального часу. На основі аналітичних правил Sentinel виявляє підозрілу активність, формує сповіщення (Alerts) та автоматично створює інциденти безпеки (Incidents). Як приклад у межах проєкту реалізовано правило виявлення множинних невдалих SSH-автентифікацій (Multiple Failed SSH Logins), що дозволяє ідентифікувати спроби brute-force атак.

Рівень автоматизованого реагування: після виявлення інциденту Microsoft Sentinel може ініціювати виконання автоматизованих сценаріїв реагування через Azure Logic Apps. Logic Apps дозволяє автоматично надсилати повідомлення адміністраторам, створювати записи про інциденти та виконувати додаткові дії реагування без участі оператора. Це скорочує час реагування на інциденти та підвищує ефективність процесів безпеки.

Рівень захисту журналів подій: для забезпечення цілісності журналів використовується Azure Storage Account із політикою Immutability Policy. Даний механізм реалізує концепцію WORM (Write Once Read Many), що унеможливорює зміну або видалення журналів після їх запису протягом визначеного терміну зберігання. Застосування незмінного сховища забезпечує збереження доказової бази для подальшого аналізу інцидентів та проведення цифрової криміналістики. Таким чином, спроектована архітектура забезпечує повний цикл роботи системи безпеки: від автентифікації користувачів і генерації подій до централізованого моніторингу, виявлення загроз, автоматизованого реагування та захищеного зберігання журналів подій.

2.4 Архітектура MVP

Для забезпечення функціонування системи безпечної хмарної інфраструктури було використано комплекс взаємопов'язаних сервісів Microsoft Azure. Кожен компонент виконує окрему функцію в процесі управління доступом, моніторингу подій безпеки, виявлення інцидентів та реагування на них та показаний на рисунку 2.1 - Архітектура MVP безпечної хмарної інфраструктури [1], [5], [6], [7]

43

Рисунок 2.1 – Архітектура MVP безпечної хмарної інфраструктури

Користувачі є джерелом взаємодії із хмарною інфраструктурою. Вони отримують доступ до ресурсів Azure відповідно до наданих ролей та політик безпеки. Будь-які дії користувачів генерують журнали подій, які надалі використовуються для моніторингу та аналізу.

Microsoft Entra ID виконує функції централізованого управління ідентичностями та доступом. Сервіс забезпечує автентифікацію користувачів, підтримує багатофакторну автентифікацію (MFA), умовний доступ (Conditional Access) та рольову модель доступу

44

(RBAC). Використання Entra ID дозволяє реалізувати принцип найменших привілеїв (Least Privilege) та мінімізувати ризик несанкціонованого доступу до ресурсів інфраструктури.

До складу ресурсів Azure входять віртуальні машини, мережеві сервіси, сховища даних та інші компоненти, необхідні для функціонування системи. У межах реалізованого MVP основним ресурсом виступає Linux-віртуальна машина Ubuntu 24.04, яка використовується як джерело подій безпеки та середовище для моделювання контрольованих сценаріїв атак. Azure Monitor забезпечує централізований збір телеметрії та журналів подій від ресурсів Azure. Сервіс отримує інформацію про активність користувачів, системні події та мережеві взаємодії. Azure Monitor виступає проміжним рівнем між джерелами даних та платформою аналітики безпеки.

Log Analytics Workspace використовується як централізоване сховище журналів подій.

Усі дані, отримані через Azure Monitor, зберігаються в робочій області та можуть аналізуватися за допомогою Kusto Query Language (KQL). Використання єдиного сховища забезпечує повну видимість подій безпеки та спрощує процес розслідування інцидентів.

Microsoft Sentinel реалізує функції Security Information and Event Management (SIEM).

Сервіс виконує аналіз журналів подій, кореляцію даних та автоматичне виявлення підозрілої активності. Для демонстрації можливостей системи було реалізовано правило виявлення множинних невдалих SSH-автентифікацій (Multiple Failed SSH Logins), яке автоматично генерує alert та incident після перевищення встановленого порогу невдалих спроб входу.

Azure Logic Apps використовується для автоматизації процесів реагування на інциденти безпеки. Після створення інциденту в Microsoft Sentinel система може автоматично виконувати визначені сценарії реагування, наприклад надсилання повідомлень адміністраторам або запуск додаткових процедур перевірки.

Email Notification є кінцевим етапом процесу автоматизованого реагування. Після виявлення інциденту система надсилає повідомлення відповідальним особам із необхідною інформацією щодо події безпеки. Використання автоматичних повідомлень дозволяє скоротити час реагування та підвищити ефективність роботи операторів безпеки.

Для забезпечення цілісності журналів подій використовується Azure Storage Account із політикою незмінності (Immutability Policy). Політика реалізує принцип WORM (Write Once Read Many), який унеможливорює зміну або видалення журналів протягом визначеного терміну зберігання. Це забезпечує збереження доказової бази для аудиту та цифрової криміналістики. Таким чином, усі компоненти архітектури формують єдину систему, яка забезпечує централізоване управління доступом, моніторинг подій безпеки, виявлення загроз та автоматизоване реагування на інциденти.

2.5 Data Flow Diagram (DFD)

Data Flow Diagram (DFD) використовується для візуалізації потоків даних між компонентами системи та визначення взаємозв'язків між джерелами даних, процесами обробки інформації та сховищами даних. У межах дипломного проєкту DFD демонструє процес передачі подій безпеки від джерела їх виникнення до механізмів виявлення інцидентів

45

та автоматизованого реагування, Рисунок 2.2 – Data Flow Diagram безпечної хмарної інфраструктури.[7], [17], [18], [19]

Рисунок 2.2 – Data Flow Diagram безпечної хмарної інфраструктури

Основний потік даних у системі складається з таких етапів:

1. Користувач виконує автентифікацію через Microsoft Entra ID та отримує доступ до ресурсів Azure.
2. Під час взаємодії з ресурсами Azure генеруються журнали подій, які містять інформацію про дії користувачів, системні процеси та події безпеки.
3. Azure Monitor збирає телеметрію та журнали подій із ресурсів хмарної інфраструктури.
4. Зібрані дані передаються до Log Analytics Workspace для централізованого зберігання та подальшого аналізу.
5. Microsoft Sentinel аналізує отримані журнали за допомогою аналітичних правил та механізмів кореляції подій.
6. У разі виявлення підозрілої активності Sentinel генерує alert та створює incident безпеки.
7. Створений інцидент передається до Azure Logic Apps для запуску автоматизованих сценаріїв реагування.
8. Logic Apps надсилає повідомлення відповідальним особам через Email Notification.
9. Копії журналів подій зберігаються в Azure Storage Account із політикою незмінності (Immutability Policy), що забезпечує їх захист від модифікації та видалення.

Запропонована схема потоків даних демонструє повний цикл обробки подій безпеки — від моменту їх виникнення до автоматизованого реагування та довготривалого захищеного зберігання журналів.

2.6 Модель загроз STRIDE

Для систематичного аналізу потенційних загроз інформаційній безпеці було використано методологію STRIDE, розроблену компанією Microsoft. Дана методика дозволяє класифікувати загрози за шістьма основними категоріями та оцінити можливі ризики для компонентів інформаційної системи. [1], [2], [3], [15]

У межах дослідження модель STRIDE застосовується до розробленої архітектури безпечної хмарної інфраструктури, що включає Microsoft Entra ID, Azure Monitor, Log Analytics Workspace, Microsoft Sentinel, Azure Storage Account та Azure Logic Apps. Результати аналізу наведено в таблиці 2.2, сама схема наведена на рисунку 2.3 - STRIDE-модель загроз для безпечної хмарної інфраструктури.

Таблиця 2.2 – Аналіз загроз за методологією STRIDE

Категорія Опис загрози Приклад реалізації Механізми захисту

Spoofing Підміна особи

Компрометація облікового

запису користувача

MFA, Conditional

Access

Tampering

Несанкціонована зміна

даних або конфігурацій

Зміна ролей доступу або

конфігурацій Azure

RBAC, Audit Logs

Repudiation

Заперечення виконаних

дій

Видалення або

приховування слідів

активності

Централізоване

логування, Immutable

Storage

Information

Disclosure

Несанкціоноване

розкриття інформації

Отримання доступу до

конфіденційних даних

Least Privilege, RBAC

Denial of

Service

Порушення доступності

сервісів

Масові запити або

перевантаження сервісів

Azure Monitor,

моніторинг

продуктивності

Elevation of

Privilege

Підвищення рівня

привілеїв

Отримання

адміністративних прав

користувачем

Sentinel Detection Rules,

RBAC

Рисунок 2.3 – STRIDE-модель загроз для безпечної хмарної інфраструктури

Найбільш критичними для досліджуваної системи є загрози компрометації облікових записів, несанкціонованого підвищення привілеїв та приховування слідів атак. Саме тому в архітектурі передбачено використання багатофакторної автентифікації, рольової моделі доступу, централізованого збору журналів подій та політики незмінності журналів (Immutability Policy).

Результати STRIDE-аналізу були використані під час проєктування архітектури системи та вибору механізмів захисту для кожного критичного компонента інфраструктури.

2.7 Аналіз поверхні атаки

Поверхня атаки (Attack Surface) являє собою сукупність усіх точок взаємодії інформаційної системи із зовнішнім середовищем, які потенційно можуть бути використані зловмисником для реалізації атаки.

Для розробленої безпечної хмарної інфраструктури було проведено аналіз основних елементів поверхні атаки та визначено потенційні ризики для кожного компонента архітектури.[4], [13], [14], [15]

Основними елементами поверхні атаки є:

- облікові записи користувачів Microsoft Entra ID;
- вебінтерфейс Microsoft Azure Portal;
- SSH-доступ до віртуальної машини Linux;
- мережеві служби Azure Virtual Machine;
- API інтерфейси Microsoft Azure;

48

- журнали подій та телеметрія;
 - механізми автоматизованого реагування Azure Logic Apps.
- Найбільш критичною точкою доступу є механізми автентифікації користувачів.

Компрометація облікового запису з адміністративними правами може призвести до отримання повного контролю над ресурсами хмарної інфраструктури.

Для зменшення ризиків реалізовано такі механізми захисту:

- використання багатофакторної автентифікації (MFA);
- застосування принципу Least Privilege;
- використання Role-Based Access Control (RBAC);
- централізований моніторинг подій безпеки;
- автоматичне виявлення підозрілої активності засобами Microsoft Sentinel;
- контроль цілісності журналів подій.

Результати аналізу показали, що найбільшу загрозу для системи становлять атаки типу Brute Force, компрометація облікових записів, спроби підвищення привілеїв та несанкціонована зміна конфігурацій ресурсів. Саме тому особлива увага приділяється контролю доступу, моніторингу подій безпеки та централізованому журналюванню – рисунок 2.3 – Аналіз поверхні атаки

Таблиця 2.3 – Аналіз поверхні атаки

Компонент	Потенційна загроза	Рівень ризику	Захисний механізм
Azure Entra ID	Компрометація акаунта	Високий	MFA, RBAC
Azure VM	Brute Force SSH	Високий	Sentinel Detection Rule
Azure Portal	Несанкціонований доступ	Високий	MFA, Conditional Access
Log Analytics	Несанкціонований перегляд логів	Середній	RBAC
Microsoft Sentinel	Зміна правил виявлення	Середній	RBAC
Azure Storage	Видалення логів	Високий	Immutability Policy
Logic Apps	Несанкціонований запуск	Середній	Azure IAM

2.8 Аналіз довірених та недовірених компонентів

Під час проєктування системи було виконано розмежування довірених та недовірених компонентів архітектури. Такий підхід дозволяє визначити межі довіри (Trust Boundaries) та зосередити механізми захисту на найбільш критичних точках взаємодії.

До довірених компонентів системи належать:

- Microsoft Entra ID;
- Terraform Repository;

- Azure Monitor;
- Log Analytics Workspace;
- Microsoft Sentinel;
- Azure Storage Account із політикою Immutability;

49

- Azure Logic Apps.

Зазначені компоненти перебувають під контролем адміністратора системи та використовуються для забезпечення автентифікації, централізованого моніторингу, зберігання журналів подій і реагування на інциденти.

До недовірених компонентів належать:

- мережа Інтернет;
- зовнішні користувачі;
- потенційно скомпрометовані облікові записи;
- внутрішні порушники;
- зовнішні атакувальники.

Основною точкою взаємодії між довіреним та недовіреним середовищем є механізм автентифікації через Microsoft Entra ID. Саме через нього здійснюється контроль доступу до ресурсів Azure.

Для мінімізації ризиків несанкціонованого доступу в архітектурі використовуються такі механізми:

- багатофакторна автентифікація (MFA);
- принцип найменших привілеїв (Least Privilege);
- рольова модель доступу RBAC;
- централізоване журналювання дій користувачів;
- автоматичне виявлення підозрілої активності засобами Microsoft Sentinel;
- захист журналів подій за допомогою політики незмінності (WORM).

Визначення меж довіри дозволило сформувати архітектуру системи таким чином, щоб мінімізувати вплив потенційних атак та забезпечити контроль усіх критичних дій користувачів і сервісів. [15], [11], [33], [34]

2.9 Архітектурні рішення щодо захисту журналів подій

Одним із ключових елементів забезпечення інформаційної безпеки є захист журналів подій від несанкціонованої модифікації або видалення. У разі успішної атаки зловмисники часто намагаються приховати свої дії шляхом видалення або зміни журналів аудиту.

Для вирішення цієї проблеми у проєкті використовується Azure Storage Account із політикою незмінності даних (Immutability Policy).

Після надходження журналів подій до централізованого сховища для них застосовується політика WORM (Write Once Read Many), яка дозволяє записати інформацію лише один раз та забороняє її зміну або видалення протягом визначеного терміну зберігання.

Використання Azure Storage Immutability забезпечує:

- цілісність журналів подій;
- захист від несанкціонованої модифікації;
- можливість проведення цифрової криміналістики;
- відповідність вимогам аудиту та комплаєнсу;
- збереження доказової бази під час розслідування інцидентів.

50

Таким чином, реалізоване рішення підвищує достовірність журналів безпеки та унеможливорює приховування слідів атак шляхом зміни або видалення записів журналювання.

[1], [2], [3]

Рисунок 2.4 – Архітектура захисту журналів подій за допомогою Azure Storage Immutability

2.10 Проєктування механізму автоматизованого реагування

Сучасні центри моніторингу безпеки (SOC) активно використовують підходи SOAR (Security Orchestration, Automation and Response) для скорочення часу реагування на інциденти інформаційної безпеки. [1], [5], [6], [16]

У межах даного проєкту механізм автоматизованого реагування реалізовано за допомогою Azure Logic Apps.

Після спрацювання аналітичного правила Microsoft Sentinel створюється Alert та відповідний Incident. Далі автоматично запускається Logic Apps Workflow, який виконує попередньо визначений сценарій реагування.

У реалізованому MVP сценарій реагування передбачає:

- отримання інформації про інцидент із Microsoft Sentinel;
- формування повідомлення;
- надсилання повідомлення адміністратору електронною поштою;
- журналювання результатів виконання процесу реагування.

Перевагами такого підходу є:

- скорочення часу реагування на інциденти;

51

- зменшення навантаження на операторів SOC;
- підвищення оперативності сповіщення;
- стандартизація процесів реагування.

У подальшому механізм може бути розширений автоматичним блокуванням облікових записів, ізоляцією ресурсів або запуском додаткових сценаріїв реагування - Рисунок 2.5 – Механізм автоматизованого реагування на інциденти безпеки. - Рисунок 2.5 – Механізм автоматизованого реагування на інциденти безпеки.

Рисунок 2.5 – Механізм автоматизованого реагування на інциденти безпеки

Висновки до другого розділу

У другому розділі було виконано проєктування безпечної хмарної інфраструктури для моніторингу, виявлення та реагування на інциденти інформаційної безпеки в середовищі Microsoft Azure. На основі аналізу сучасних загроз хмарних середовищ сформовано архітектуру системи, яка поєднує механізми управління доступом, централізованого логування, моніторингу подій безпеки та автоматизованого реагування на інциденти.

У процесі проєктування визначено основні компоненти майбутньої системи: Azure Entra ID для управління ідентифікацією та доступом користувачів, Terraform для реалізації підходу Infrastructure as Code, Azure Monitor і Log Analytics Workspace для централізованого збору журналів подій, Microsoft Sentinel для виявлення загроз і кореляції подій безпеки, Azure Storage Account з політикою незмінності даних (Immutability Policy) для захисту журналів від модифікації, а також Azure Logic Apps для автоматизації процесів реагування.

52

Побудована модель загроз STRIDE дозволила визначити потенційні сценарії атак на систему та обґрунтувати використання відповідних механізмів захисту. Особливу увагу приділено реалізації принципів Least Privilege та Zero Trust, які спрямовані на мінімізацію ризиків несанкціонованого доступу до ресурсів хмарної інфраструктури.

У результаті проєктування сформовано цілісну архітектуру безпечного хмарного середовища, що забезпечує централізований контроль подій безпеки, можливість своєчасного виявлення підозрілої активності та підтримку автоматизованого реагування на інциденти.

Запропоновані архітектурні рішення відповідають сучасним вимогам Cloud Security та можуть бути використані як основа для побудови систем моніторингу безпеки в організаціях різного масштабу.

Отримані результати проєктування створюють необхідну теоретичну та архітектурну основу для практичної реалізації системи. У наступному розділі буде розглянуто процес розгортання та налаштування компонентів безпечної хмарної інфраструктури в середовищі Microsoft Azure, а також результати їх практичного впровадження та тестування.

53

РОЗДІЛ 3. РЕАЛІЗАЦІЯ СИСТЕМИ

3.1 Створення інфраструктури за допомогою Terraform

Для автоматизації процесу розгортання хмарної інфраструктури в межах дипломного проєкту було використано підхід Infrastructure as Code (IaC). Реалізація IaC виконувалася за допомогою інструмента Terraform, який дозволяє описувати конфігурацію інфраструктури у вигляді декларативного коду та забезпечує повторюваність процесу розгортання ресурсів.[8], [9], [10], [4]

Використання Terraform дозволяє зменшити кількість ручних операцій під час

налаштування середовища, забезпечити контроль версій конфігурації та спростити процес відтворення інфраструктури в разі необхідності повторного розгортання системи. У межах реалізації проєкту було створено Terraform-конфігурацію, яка забезпечує автоматизоване розгортання базових компонентів хмарної інфраструктури Microsoft Azure. Для взаємодії з платформою Azure використовувався офіційний провайдер AzureRM. Перед початком розгортання було виконано ініціалізацію Terraform-проєкту, перевірку коректності конфігурації та генерацію плану виконання. Після успішної валідації конфігурації було виконано команду Terraform Apply, яка створила необхідні ресурси в середовищі Microsoft Azure.

У результаті виконання Terraform-конфігурації були автоматично створені такі компоненти:

- Resource Group для розміщення ресурсів проєкту;
- Azure Log Analytics Workspace;
- компоненти моніторингу та журналювання;
- ресурси, необхідні для інтеграції з Microsoft Sentinel;
- допоміжні налаштування інфраструктури.

Та наведені у Таблиця 3.1 – Ресурси, створені за допомогою Terraform

Таблиця 3.1 – Ресурси, створені за допомогою Terraform

Ресурс Призначення

Resource Group Групування ресурсів проєкту

Storage Account Зберігання журналів подій

Blob Container Розміщення захищених логів

54

Ресурс Призначення

Immutability Policy Захист журналів від змін

Diagnostic Settings Передача логів до Azure Monitor

На рисунку 3.1 наведено структуру Terraform-проєкту та основні конфігураційні файли.

Рисунок 3.1 – Структура Terraform-проєкту та конфігураційні файли

55

Після підготовки конфігурації було виконано перевірку та розгортання інфраструктури за допомогою Terraform. Результат успішного виконання процесу розгортання наведено на рисунку 3.2.

Рисунок 3.2 – Успішне виконання Terraform Apply та створення ресурсів Azure

Використання Terraform дозволило автоматизувати процес створення інфраструктури, зменшити ризик помилок ручного налаштування та забезпечити можливість повторного розгортання середовища відповідно до принципів Infrastructure as Code - Рисунок 3.3 – План створення ресурсів Azure за допомогою Terraform.

56

Рисунок 3.3 – План створення ресурсів Azure за допомогою Terraform

3.2 Налаштування Azure Entra ID

Для забезпечення централізованого керування обліковими записами та контролю доступу в межах реалізованої хмарної інфраструктури було використано сервіс Microsoft Entra ID (раніше Azure Active Directory).

Microsoft Entra ID забезпечує механізми автентифікації та авторизації користувачів, підтримує централізоване керування ідентичностями та інтегрується з усіма основними сервісами платформи Microsoft Azure. Використання єдиного каталогу ідентичностей

57

дозволяє реалізувати принципи Zero Trust та Least Privilege, що були визначені серед основних вимог до системи.

У межах даного проєкту було використано тенант Microsoft Entra ID, який забезпечував доступ до ресурсів Azure, включаючи Resource Groups, Storage Account, Azure Monitor, Log Analytics Workspace та Microsoft Sentinel.

На рисунку 3.4 наведено загальний вигляд налаштованого середовища Microsoft Entra ID.

Рисунок 3.4 – Огляд середовища Microsoft Entra ID

Усі операції з керування ресурсами виконувалися через обліковий запис адміністратора тенанта. Використання Microsoft Entra ID дозволило забезпечити єдину точку автентифікації та централізоване управління доступом до компонентів реалізованої системи. Крім того, інтеграція Entra ID з Azure RBAC створює основу для подальшого розмежування прав доступу між користувачами та сервісами, що є важливою вимогою сучасних хмарних середовищ.

3.3 Реалізація моделі Role-Based Access Control (RBAC)

Для забезпечення контролю доступу до ресурсів хмарної інфраструктури було використано механізм Role-Based Access Control (RBAC), який є стандартною моделлю розмежування прав доступу в Microsoft Azure.

58

RBAC дозволяє надавати користувачам та сервісам лише ті дозволи, які необхідні для виконання їхніх функцій. Такий підхід відповідає принципу Least Privilege, який передбачає мінімізацію рівня доступу до ресурсів системи.

У межах реалізованого проєкту керування доступом здійснювалося через сервіс Access Control (IAM). Для користувачів та службових облікових записів були призначені ролі відповідно до їхніх функцій у системі моніторингу та реагування на інциденти.

На рисунку 3.5 наведено приклад налаштування ролей доступу в межах групи ресурсів проєкту.

Рисунок 3.5 – Налаштування ролей доступу за допомогою Azure RBAC

У реалізованій системі використовувалися такі основні ролі:

Таблиця 3.2 – Використані ролі Azure RBAC

Роль	Призначення
Owner	Повний контроль над ресурсами проєкту
Log Analytics Data Reader	Перегляд даних журналів та результатів моніторингу
Microsoft Sentinel Contributor	Виконання операцій моніторингу та управління інцидентами
Service Principal	Виконання автоматизованих сервісних операцій

59

Призначення ролей забезпечило контрольований доступ до компонентів системи безпеки та дозволило розділити адміністративні функції між користувачами та службовими обліковими записами.

Використання RBAC також дозволило обмежити доступ до критичних ресурсів, таких як Log Analytics Workspace, Microsoft Sentinel та Azure Storage Account, що знижує ризик несанкціонованих змін конфігурації або видалення журналів подій.

Таким чином, реалізована модель RBAC забезпечує централізоване керування правами доступу та відповідає сучасним вимогам до безпеки хмарних середовищ.

3.4 Налаштування Azure Monitor

Azure Monitor є одним із ключових компонентів реалізованої хмарної інфраструктури безпеки. Основним призначенням сервісу є централізований збір телеметрії, системних журналів та метрик від ресурсів Microsoft Azure з подальшою передачею даних до Log Analytics Workspace та Microsoft Sentinel для аналізу подій безпеки. У межах даного проєкту Azure Monitor використовується як проміжний рівень між віртуальною машиною Linux та

системою виявлення інцидентів Microsoft Sentinel.

Основною задачею впровадження Azure Monitor було забезпечення централізованого збору системних журналів із віртуальної машини vm-thesis, що використовується як тестове середовище для демонстрації механізмів моніторингу та виявлення інцидентів безпеки. Для цього необхідно було виконати встановлення Azure Monitor Agent, створення правила збору даних Data Collection Rule та перевірку надходження журналів до робочої області Log Analytics Workspace.

3.4.1 Встановлення Azure Monitor Agent

Для збору телеметрії на віртуальній машині Ubuntu 24.04 було встановлено Azure Monitor Agent (AMA). Azure Monitor Agent є сучасним агентом моніторингу Microsoft, який забезпечує передачу журналів подій, системних повідомлень та іншої телеметрії до сервісів моніторингу Azure. На відміну від попередніх агентів, AMA використовує централізоване управління через Data Collection Rules, що спрощує масштабування та адміністрування середовища моніторингу.

Після розгортання агента було виконано перевірку його статусу через Azure Portal. Результати підтвердили успішне встановлення агента на віртуальній машині vm-thesis та готовність до передачі журналів подій у систему моніторингу.

60

Рисунок 3.6 Azure Monitor Agent, встановлений на віртуальній машині vm-thesis для передачі системних журналів до Azure Monitor та Log Analytics Workspace

3.4.2 Створення Data Collection Rule

Після встановлення агента було створено правило збору даних Data Collection Rule (DCR). Data Collection Rule визначає логіку збору телеметрії та встановлює зв'язок між джерелом даних і кінцевим сховищем журналів. У межах проєкту джерелом даних виступала віртуальна машина Linux vm-thesis, а приймачем журналів — робоча область Log Analytics Workspace law-thesis-soc-us2.

Під час налаштування DCR було визначено перелік журналів, які необхідно збирати для подальшого аналізу подій безпеки. Основну увагу було приділено системним журналам Syslog, оскільки саме вони містять інформацію про процеси автентифікації, запуск служб та інші події операційної системи Linux. Дані журнали надалі використовуються Microsoft Sentinel для виявлення підозрілої активності та формування інцидентів безпеки. Після застосування правила збору даних було підтверджено, що Azure Monitor Agent успішно отримує та передає системні журнали до централізованого сховища.

61

Рисунок 3.7 Створене правило Data Collection Rule для збору Syslog-подій із віртуальної машини vm-thesis.

3.4.3 Перевірка передачі телеметрії

Для перевірки працездатності каналу передачі телеметрії було використано таблицю Heartbeat у Log Analytics Workspace. Таблиця Heartbeat містить службові записи, які регулярно надсилаються агентом моніторингу та дозволяють контролювати стан підключених ресурсів.

Після виконання відповідного запиту в Log Analytics було отримано записи від віртуальної машини vm-thesis. Наявність регулярних записів підтвердила коректну роботу Azure Monitor Agent, успішне застосування Data Collection Rule та функціонування каналу передачі даних між Linux-віртуальною машиною та Azure Monitor.

Отримані результати підтвердили працездатність усіх компонентів підсистеми моніторингу та готовність середовища до подальшої інтеграції з Microsoft Sentinel.

Висновки до підрозділу 3.4

У результаті виконаних робіт було успішно розгорнуто та налаштовано Azure Monitor як компонент централізованого моніторингу хмарної інфраструктури. Було встановлено Azure Monitor Agent на віртуальну машину vm-thesis, створено Data Collection Rule для збору Syslog-подій та підтверджено надходження телеметрії до Log Analytics Workspace. Реалізований

механізм забезпечив побудову каналу передачі журналів:

62

Linux VM → Azure Monitor Agent → Data Collection Rule → Log Analytics Workspace
Створена підсистема моніторингу стала основою для подальшого налаштування Microsoft Sentinel та реалізації механізмів автоматичного виявлення інцидентів безпеки.

3.5 Розгортання Log Analytics Workspace

Для реалізації централізованого збору та зберігання журналів подій у межах проєкту було використано сервіс Microsoft Azure Log Analytics Workspace. Даний компонент виконує роль централізованого сховища телеметрії та журналів безпеки, які надходять від віртуальних машин, Azure Monitor та Microsoft Sentinel.

Log Analytics Workspace забезпечує:

- централізоване зберігання журналів подій;
- виконання запитів мовою Kusto Query Language (KQL);
- інтеграцію з Microsoft Sentinel;
- довгострокове зберігання телеметрії;
- підтримку механізмів виявлення інцидентів безпеки.

У межах реалізації дипломного проєкту було створено робочу область law-thesis-soc-us2, яка використовується як основне сховище журналів подій для побудованої хмарної інфраструктури. Робоча область була розгорнута в середовищі Microsoft Azure та інтегрована з компонентами Azure Monitor і Microsoft Sentinel.

63

Рисунок 3.8 – Створена робоча область Log Analytics Workspace law-thesis-soc-us2

Після створення робочої області було виконано її підключення до віртуальної машини Linux vm-thesis через Azure Monitor Agent та Data Collection Rule. Така архітектура забезпечує автоматичну передачу телеметрії та системних журналів до централізованого сховища для подальшого аналізу.

Передача даних здійснюється за наступною схемою:

Linux VM → Azure Monitor Agent → Data Collection Rule → Log Analytics Workspace

64

Після завершення налаштування було підтверджено успішне надходження службових повідомлень від віртуальної машини до робочої області. Для цього використовувалась системна таблиця Heartbeat, яка містить інформацію про стан підключених ресурсів.

Рисунок 3.9 – Heartbeat-події в Log Analytics Workspace

Для перевірки працездатності каналу збору логів було виконано запит до таблиці

Heartbeat:

Heartbeat

| sort by TimeGenerated desc

Результати виконання запиту підтвердили регулярне надходження службових повідомлень від віртуальної машини vm-thesis. Це свідчить про коректну роботу Azure Monitor Agent та успішну передачу телеметрії до Log Analytics Workspace.

Крім службової телеметрії, до робочої області надходять системні журнали Linux, зокрема записи Syslog, які використовуються для подальшого аналізу подій безпеки та роботи аналітичних правил Microsoft Sentinel.

65

Рисунок 3.10 – Журнали Syslog у Log Analytics Workspace

Таким чином, у межах реалізації дипломного проєкту було успішно розгорнуто та

налаштовано Log Analytics Workspace, який забезпечує централізований збір, зберігання та аналіз журналів подій.Робоча область стала ключовим компонентом архітектури моніторингу та надалі використовується Microsoft Sentinel для виявлення інцидентів безпеки, генерації сповіщень та автоматизованого реагування на загрози.[1], [5], [6], [2]

3.6 Інтеграція Microsoft Sentinel

Для реалізації функцій моніторингу подій безпеки та виявлення інцидентів у межах проєкту було використано систему керування подіями та інформацією безпеки (SIEM) Microsoft Sentinel.Sentinel є хмарним рішенням класу SIEM та SOAR, яке забезпечує централізований аналіз журналів подій, автоматизоване виявлення загроз та підтримку процесів реагування на інциденти безпеки.

Після створення робочої області Log Analytics Workspace було виконано підключення Microsoft Sentinel до робочої області law-thesis-soc-us2.У результаті Sentinel отримав доступ до журналів подій, що надходять від віртуальної машини Linux через Azure Monitor Agent та Data Collection Rule.

66

Архітектура обробки подій має такий вигляд:

Після підключення Sentinel було перевірено надходження даних до робочої області та можливість їх аналізу за допомогою Kusto Query Language (KQL).Як джерело даних використовувалися журнали Syslog операційної системи Linux. Саме ці журнали містять інформацію про автентифікацію користувачів, роботу системних служб та події безпеки.

67

Рисунок 3.11 – Підключення Microsoft Sentinel до Log Analytics Workspace

Для перевірки працездатності інтеграції було виконано декілька KQL-запитів до таблиці Syslog.Перший запит використовувався для підтвердження надходження системних журналів від віртуальної машини vm-thesis.

```
Syslog
| where TimeGenerated > ago(10m)
| sort by TimeGenerated desc
```

Результати виконання запиту підтвердили наявність системних подій Linux у робочій області Log Analytics Workspace.Для подальшого аналізу було виконано фільтрацію подій SSH-служби за допомогою процесу sshd.

```
Syslog
| where ProcessName == "sshd"
| sort by TimeGenerated desc
```

У результатах були виявлені повідомлення типу Failed password, Invalid user та інші події автентифікації, які надалі використовувалися для побудови аналітичного правила Microsoft Sentinel.

68

Рисунок 3.12 – Аналіз Syslog-подій у Microsoft Sentinel

Однією з ключових функцій Sentinel є використання аналітичних правил (Analytics Rules), які дозволяють автоматично виявляти підозрілу активність на основі журналів подій. У межах проєкту було реалізовано правило виявлення множинних невдалих SSH-

автентифікацій під назвою Multiple Failed SSH Logins.

Правило було створене як Scheduled Analytics Rule та відноситься до категорії MITRE ATT&CK T1110 (Brute Force) і T1110.001 (Password Guessing). Рівень критичності правила встановлено як Medium.

Для реалізації логіки виявлення використовувався наступний KQL-запит:

```
Syslog
| where ProcessName == "sshd"
| where SyslogMessage has_any ("Failed password","Invalid user")
| extend SourceIP = extract(@"from ([0-9]+\.[0-9]+\.[0-9]+\.[0-9]+)",1,SyslogMessage)
| extend Account = extract(@"for ([^ ]+)",1,SyslogMessage)
| summarize FailedAttempts=count()
by SourceIP, Account, Computer, bin(TimeGenerated,15m)
| where FailedAttempts >= 5
```

Правило запускалося кожні п'ять хвилин та аналізувало події за останні п'ять хвилин.

Якщо кількість невдалих спроб автентифікації перевищувала встановлений поріг, Sentinel

69

автоматично створював сповіщення (Alert) та інцидент (Incident) для подальшого розслідування.

Рисунок 3.13 – Аналітичне правило Microsoft Sentinel «Multiple Failed SSH Logins»

Для покращення процесу розслідування було налаштовано механізм Entity Mapping.

Як сутності використовувалися:

- IP Address (SourceIP);
- Account;
- Host (Computer).

Це дозволяє Sentinel автоматично пов'язувати інцидент із конкретною IP-адресою джерела атаки, обліковим записом користувача та віртуальною машиною, що значно спрощує подальший аналіз інцидентів безпеки.

70

Рисунок 3.14 – Налаштування Entity Mapping

Для перевірки працездатності аналітичного правила було виконано симуляцію множинних невдалих SSH-автентифікацій на віртуальній машині Linux. Після перевищення встановленого порогового значення Microsoft Sentinel автоматично сформував сповіщення та створив інцидент безпеки для подальшого розслідування. Створений інцидент підтвердив коректність роботи механізму виявлення загроз та інтеграції між Log Analytics Workspace і Microsoft Sentinel.

Рисунок 3.15 – Інцидент безпеки «Multiple Failed SSH Logins», автоматично сформований Microsoft Sentinel

Як видно з рисунка 3.14, Microsoft Sentinel успішно виявив підозрілу активність, класифікував її відповідно до налаштованого аналітичного правила та створив інцидент безпеки. Інцидент отримав рівень критичності Medium та містив інформацію, необхідну для подальшого аналізу події. Таким чином було підтверджено працездатність реалізованого механізму моніторингу та автоматичного виявлення атак типу Brute Force на SSH-службу Linux.

Отримані результати підтвердили успішну інтеграцію Microsoft Sentinel з

компонентами Azure Monitor та Log Analytics Workspace. Реалізовані аналітичні правила дозволили автоматично виявляти підозрілу активність, створювати сповіщення та формувати інциденти безпеки. Це підтверджує працездатність побудованої SIEM-підсистеми та відповідність реалізованого рішення поставленим вимогам щодо моніторингу та реагування на інциденти.

Таким чином, інтеграція Microsoft Sentinel забезпечила централізований моніторинг журналів подій, автоматичне виявлення підозрілої активності та формування інцидентів безпеки. Використання аналітичних правил і механізму Entity Mapping дозволило реалізувати базові функції SIEM-системи в межах створеного MVP безпечної хмарної інфраструктури.

72

3.7. Налаштування збору та централізації логів

Одним із ключових елементів побудованої системи кібербезпеки є централізований збір журналів подій. Наявність єдиного сховища журналів забезпечує можливість своєчасного виявлення підозрілої активності, проведення розслідування інцидентів та збереження історії подій незалежно від окремих компонентів інфраструктури.

У реалізованому проєкті збір журналів здійснюється за допомогою Azure Monitor Agent та Data Collection Rule, після чого всі журнали передаються до Log Analytics Workspace.

Саме Log Analytics Workspace виступає централізованим сховищем телеметрії, яке використовується Microsoft Sentinel для виконання аналітичних запитів і побудови правил виявлення інцидентів.

Для перевірки працездатності реалізованої системи було виконано тестування передачі службових повідомлень та системних журналів Linux-віртуальної машини vm-thesis.

Для підтвердження коректної роботи каналу передачі телеметрії було виконано запит до таблиці Heartbeat у Log Analytics Workspace. Таблиця містить службові повідомлення, які регулярно надсилаються Azure Monitor Agent та дозволяють контролювати стан підключених ресурсів.

Отримані записи підтвердили, що віртуальна машина vm-thesis успішно взаємодіє з Azure Monitor та регулярно передає службову телеметрію до централізованого сховища журналів.

Рисунок 3.16 – Записи Heartbeat у Log Analytics Workspace, що підтверджують успішну передачу телеметрії від віртуальної машини vm-thesis.

73

Після підтвердження працездатності каналу передачі телеметрії було перевірено надходження системних журналів Linux. Для цього використано таблицю Syslog та KQL-запит, який дозволяє переглядати останні записи журналів.

Syslog

```
| where TimeGenerated > ago(10m)
```

```
| sort by TimeGenerated desc
```

Рисунок 3.17 – Системні журнали Syslog, отримані від віртуальної машини vm-thesis у Log Analytics Workspace

Для перевірки збору подій автентифікації було виконано фільтрацію журналів за процесом sshd. Це дозволило виділити записи, пов'язані зі спробами встановлення SSH-

з'єднання та автентифікації користувачів.

Syslog

| where ProcessName == "sshd"

| sort by TimeGenerated desc

74

Рисунок 3.18 – Журнали автентифікації SSH, отримані із Syslog та використані для подальшого аналізу в Microsoft Sentinel

Отримані результати підтвердили коректну роботу механізму централізованого збору журналів. Усі службові повідомлення та системні журнали Linux-віртуальної машини успішно передаються до Log Analytics Workspace, де можуть використовуватися Microsoft Sentinel для побудови аналітичних правил, виявлення підозрілої активності та подальшого реагування на інциденти безпеки. Таким чином, реалізований механізм централізованого логування забезпечує необхідну основу для функціонування SIEM-рішення та відповідає вимогам побудови сучасної системи моніторингу безпеки.

3.8. Реалізація Azure Storage Immutability Policy

Після налаштування централізованого збору журналів виникає наступна задача — забезпечення їхньої цілісності та захисту від несанкціонованого видалення або зміни. У традиційних системах журнали можуть бути змінені або видалені зловмисником після компрометації сервера, що унеможливило проведення повноцінного розслідування інциденту. Для усунення цієї проблеми в межах дипломного проекту було використано сервіс Azure Storage Account із підтримкою політики Immutability Policy (WORM — Write Once Read Many). Дана політика забезпечує незмінність збережених журналів протягом визначеного терміну зберігання та гарантує неможливість їх модифікації або видалення навіть адміністраторами системи.

75

Таким чином реалізується один із ключових принципів безпечного зберігання журналів подій, який використовується в сучасних корпоративних SIEM-рішеннях.

3.8.1 Створення Azure Storage Account

У межах реалізації проекту було створено окремий Azure Storage Account, призначений для довготривалого зберігання журналів безпеки. Для зберігання журналів було створено Blob Container securitylogs, який використовується як захищене сховище логів. Під час створення Storage Account було використано стандартний тип реплікації LRS (Locally Redundant Storage), що забезпечує локальне резервування даних у межах одного регіону Microsoft Azure.

Для довготривалого зберігання журналів подій у межах реалізації дипломного проекту було створено окремий контейнер securitylogs у сховищі Azure Blob Storage. Використання окремого контейнера дозволяє централізовано зберігати журнали безпеки та застосовувати до них політики захисту від модифікації і видалення.

Рисунок 3.19 – Контейнер securitylogs у сховищі Azure Blob Storage, призначений для зберігання журналів подій

Створений контейнер використовується для зберігання журналів, які можуть бути експортовані із системи централізованого моніторингу. Використання окремого контейнера дозволяє відокремити журнали безпеки від інших даних та застосувати до них спеціальні політики захисту.

76

3.8.2 Налаштування Immutability Policy

Для захисту журналів від модифікації було використано Azure Blob Immutability Policy.

Під час налаштування було обрано режим WORM (Write Once Read Many), який дозволяє один раз записати файл та забороняє будь-які зміни до завершення визначеного

періоду зберігання.

У межах реалізації дипломного проєкту було встановлено термін незмінності 30 днів.

Після активації політики система автоматично блокує такі операції:

- видалення Blob;
- зміну Blob;
- перезапис Blob;
- зміну метаданих.

Це гарантує цілісність журналів та забезпечує можливість проведення цифрової криміналістики навіть після компрометації окремих компонентів інфраструктури.

Рисунок 3.20 – Налаштування Azure Blob Immutability Policy для контейнера securitylogs

Як показано на рисунку 3.21, для контейнера securitylogs налаштовано політику зберігання на основі часу (Time-based Retention) із періодом 30 днів. На момент реалізації проєкту політика перебувала у стані Unlocked (розблоковано), що дозволяє змінювати її параметри під час тестування. Після переведення політики у стан Locked модифікація або

77

видалення об'єктів до завершення терміну зберігання стає неможливою, що відповідає принципам WORM-зберігання.

Після активації політики Azure автоматично застосовує обмеження на всі об'єкти контейнера. Будь-яка спроба видалення або модифікації журналів завершується помилкою доступу, що гарантує незмінність збережених даних протягом визначеного терміну.

Таблиця 3.3 – Основні параметри політики незмінності Azure Blob Storage

Параметр	Значення
Сховище Azure Blob Storage	
Контейнер securitylogs	
Тип політики	Time-based Retention (WORM)
Період зберігання	30 днів
Область застосування	Контейнер
Поточний стан	Unlocked (розблоковано)

Використання Azure Storage Immutability Policy дозволило реалізувати механізм довготривалого захисту журналів безпеки від модифікації та видалення. Завдяки використанню технології WORM забезпечується збереження цілісності журналів, що є необхідною умовою проведення подальшого аналізу інцидентів інформаційної безпеки та відповідає сучасним вимогам до побудови захищених хмарних середовищ.

3.9. Створення правил виявлення інцидентів

3.9.1 Створення аналітичного правила Microsoft Sentinel

Після налаштування централізованого збору журналів та інтеграції Microsoft Sentinel наступним етапом стало створення правила виявлення інцидентів (Analytics Rule). Його призначенням є автоматичний аналіз системних журналів Linux та формування сповіщень у разі виявлення підозрілої активності.[16], [7], [17], [18]

У межах дипломного проєкту було реалізовано Scheduled Analytics Rule з назвою Multiple Failed SSH Logins, призначене для виявлення багаторазових невдалих спроб автентифікації через SSH на віртуальній машині vm-thesis.

Правило використовує журнали Syslog, які надходять до Log Analytics Workspace через Azure Monitor Agent, після чого Microsoft Sentinel виконує їх аналіз за допомогою мови запитів Kusto Query Language (KQL).

78

Для створеного правила було визначено такі параметри.

Таблиця 3.4 – Основні параметри правила виявлення інцидентів

Параметр	Значення
Назва правила	Multiple Failed SSH Logins
Тип	Scheduled Analytics Rule
Джерело даних	Syslog
Сервіс	sshd
Рівень критичності	Medium
Тактика	MITRE ATT&CK Credential Access

Техніка T1110 Brute Force
Період аналізу 5 хвилин
Частота запуску кожні 5 хвилин
Результат Alert + Incident

На рисунку 3.22 показано створене правило аналітики Microsoft Sentinel, яке використовується для автоматичного виявлення множинних невдалих SSH-автентифікацій.

Рисунок 3.21 Microsoft Sentinel. Аналітичне правило "Multiple Failed SSH Logins" для автоматичного виявлення множинних невдалих SSH-автентифікацій

79

На рисунку 3.22 наведено створене аналітичне правило Multiple Failed SSH Logins у Microsoft Sentinel. Правило має тип Scheduled Analytics Rule та виконує автоматичний аналіз журналів Syslog, що надходять від віртуальної машини vm-thesis. Для правила встановлено рівень критичності Medium, а також визначено відповідність тактиці Credential Access згідно з матрицею MITRE ATT&CK. Після виконання запиту KQL Microsoft Sentinel автоматично формує сповіщення (Alert), яке використовується для створення інциденту безпеки.

Рисунок 3.22 – Результати виконання аналітичного правила "Multiple Failed SSH Logins" у Microsoft Sentinel

На рисунку 3.23 показано результат виконання аналітичного правила Microsoft Sentinel. У результаті аналізу журналів Syslog було виявлено 13 невдалих спроб автентифікації через SSH на віртуальній машині vm-thesis, що перевищує встановлений поріг спрацювання правила та призводить до формування сповіщення.

80

Рисунок 3.23 – Інцидент безпеки "Multiple Failed SSH Logins", автоматично створений Microsoft Sentinel після спрацювання аналітичного правила

Після виявлення багаторазових невдалих спроб SSH-автентифікації Microsoft Sentinel автоматично сформував інцидент безпеки. Як показано на рисунку 3.20, інцидент отримав рівень критичності Medium, містить інформацію про пов'язане сповіщення та може використовуватися аналітиком для подальшого розслідування.

3.9.2 Реалізація KQL-запиту

Основою роботи правила є аналіз журналів Syslog за допомогою Kusto Query Language (KQL). Запит здійснює пошук повідомлень SSH-служби, які містять ознаки невдалої автентифікації.

```
Syslog
| where ProcessName == "sshd"
| where SyslogMessage has_any ("Failed password","Invalid user")
| extend SourceIP = extract(@"from ([0-9]+\.[0-9]+\.[0-9]+\.[0-9]+)",1,SyslogMessage)
| extend Account = extract(@"for ([^ ]+)",1,SyslogMessage)
| summarize FailedAttempts=count()
by SourceIP, Account, Computer, bin(TimeGenerated,15m)
| where FailedAttempts >= 5
```

81

Запит аналізує журнали Syslog, отримані від процесу sshd, виділяє IP-адресу джерела атаки, ім'я користувача та підраховує кількість невдалих спроб входу протягом 15 хвилин. Якщо кількість невдалих автентифікацій перевищує п'ять, Microsoft Sentinel створює сповіщення про інцидент.

3.9.3 Відповідність MITRE ATT&CK

Для спрощення аналізу інцидентів правило було віднесено до відповідної тактики та техніки MITRE ATT&CK.

Таблиця 3.5 – Відповідність MITRE ATT&CK

Категорія	Значення
Тактика	Credential Access
Техніка	T1110
Підтехніка	T1110.001 Password Guessing

3.9.4 Налаштування Entity Mapping

Для автоматичного пов'язування інцидентів із джерелами атаки було налаштовано Entity Mapping.

Таблиця 3.6 – Entity Mapping

Entity	Значення
IP Address	SourceIP
Account	Account
Host	Computer

Таким чином, у Microsoft Sentinel було реалізовано аналітичне правило для автоматичного виявлення багаторазових невдалих SSH-автентифікацій. Використання KQL-запиту забезпечує своєчасне виявлення ознак атаки типу Brute Force та автоматичне створення інцидентів безпеки для подальшого аналізу.

3.10 Реалізація автоматизованого реагування через Azure Logic Apps

Після реалізації механізму автоматичного виявлення інцидентів у Microsoft Sentinel наступним етапом стало налаштування автоматизованого реагування. Для цього було використано сервіс Azure Logic Apps, який дозволяє автоматизувати виконання послідовності дій після виникнення події безпеки без необхідності втручання адміністратора. У межах дипломного проєкту Logic Apps інтегровано з Microsoft Sentinel для автоматичного запуску робочого процесу після створення інциденту безпеки. Основною функцією реалізованого сценарію є отримання інформації про інцидент та її подальша передача до механізму сповіщення, що скорочує час реагування та мінімізує вплив людського фактора. Використання Azure Logic Apps відповідає концепції Security Orchestration, Automation and Response (SOAR) та забезпечує автоматизацію типових операцій реагування на інциденти.

Таблиця 3.7 – Основні параметри Azure Logic Apps

Параметр	Значення
Сервіс	Azure Logic Apps
Тип робочого процесу	Consumption
Джерело запуску	Microsoft Sentinel Incident Trigger
Тип запуску	Автоматичний
Основна дія	Надсилання повідомлення про інцидент
Інтеграція	Microsoft Sentinel

Для автоматизації реагування на інциденти безпеки було створено робочий процес Azure Logic Apps під назвою blob-delete-response. Робочий процес функціонує у середовищі Microsoft Azure та інтегрований із Microsoft Sentinel. Після створення інциденту Logic App автоматично запускає визначений сценарій реагування. На рисунку 3.25 наведено загальний вигляд створеного робочого процесу та його основні параметри.

Рисунок 3.24 Azure Logic App, створений для автоматизованого реагування на інциденти Microsoft Sentinel

Рисунок 3.25 Структура Workflow Azure Logic Apps із тригером Microsoft Sentinel та дією надсилання повідомлення

Робочий процес складається з двох основних етапів. Першим елементом є тригер Microsoft Sentinel Incident, який автоматично активується після створення нового інциденту безпеки. Після отримання події виконується дія Add comment to incident (V3), яка автоматично додає службовий коментар до картки інциденту в Microsoft Sentinel. Такий підхід демонструє

84

можливість автоматизованого реагування без участі адміністратора та підтверджує інтеграцію Microsoft Sentinel із сервісом Azure Logic Apps.

У результаті виконання роботи було реалізовано механізм автоматизованого реагування на інциденти безпеки із використанням Azure Logic Apps. Створений робочий процес інтегровано з Microsoft Sentinel, що забезпечує автоматичний запуск сценарію після виникнення інциденту. Реалізоване рішення відповідає принципам SOAR (Security Orchestration, Automation and Response) та демонструє можливість автоматизації типових операцій реагування у хмарному середовищі Microsoft Azure.

3.11. Реалізація сповіщень про інциденти

Для подальшого розвитку рішення передбачено можливість інтеграції Logic Apps із сервісом Office 365 Outlook для автоматичного надсилання повідомлень адміністраторам безпеки. На момент реалізації проекту функціональність підготовлена, однак через обмеження авторизації навчальної підписки Microsoft Azure повне підключення до сервісу Outlook не було виконано.

Рисунок 3.26 – Робочий процес Azure Logic Apps із дією надсилання email-повідомлення про інцидент безпеки

Для підвищення ефективності реагування на кіберінциденти в проєкті передбачено використання сервісу Azure Logic Apps для автоматичного інформування адміністратора безпеки про виявлені загрози. Після створення інциденту в Microsoft Sentinel автоматизований

85

робочий процес (Workflow) може виконувати декілька послідовних дій, зокрема додавання коментаря до інциденту та надсилання повідомлення електронною поштою відповідальним особам.

У процесі реалізації було створено логічний робочий процес blob-delete-response, який інтегрується з Microsoft Sentinel та виконує автоматичну обробку інцидентів. До складу Workflow входить три основні етапи: отримання інформації про інцидент із Microsoft Sentinel, автоматичне додавання коментаря до картки інциденту та надсилання повідомлення електронною поштою за допомогою Office 365 Outlook.

Під час тестування було підтверджено коректне створення та виконання Workflow, а також успішну інтеграцію з Microsoft Sentinel. Підключення до сервісу Office 365 Outlook вимагало додаткової авторизації, яка не була завершена через обмеження навчального середовища Microsoft Azure. Незважаючи на це, архітектура автоматизованого реагування була повністю реалізована та підготовлена до використання після завершення процедури авторизації. [16], [7], [17], [18]

Таблиця 3.8 – Стан реалізації основних компонентів розробленої системи

Компонент Стан реалізації

Terraform Реалізовано

Azure Monitor Реалізовано

Log Analytics

Workspace

Реалізовано

Microsoft Sentinel Реалізовано

Detection Rules Реалізовано

Azure Logic Apps Реалізовано

Email Notification

Частково реалізовано (авторизація Outlook не завершена через обмеження навчального середовища)

Висновки до третього розділу

У третьому розділі дипломної роботи було реалізовано практичну частину запропонованої системи моніторингу та реагування на кіберінциденти із використанням хмарної платформи Microsoft Azure.

У ході виконання роботи було розгорнуто необхідну інфраструктуру в Azure, налаштовано службу Microsoft Entra ID для керування доступом, створено віртуальну машину

86

під керуванням Linux, а також розгорнуто Azure Monitor і Log Analytics Workspace для централізованого збору та аналізу журналів подій.

На наступному етапі виконано інтеграцію Log Analytics Workspace із Microsoft Sentinel, що дозволило здійснювати централізований моніторинг подій безпеки та використовувати можливості SIEM-платформи для аналізу отриманих журналів. Було реалізовано збір системних журналів Syslog, журналів автентифікації SSH та телеметрії Azure Monitor Agent, що забезпечило отримання необхідної інформації для виявлення потенційних загроз.

Для забезпечення цілісності журналів подій створено окремий контейнер Azure Storage та налаштовано політику незмінності (Immutable Blob Storage). Це дозволяє захистити журнали від модифікації або видалення протягом визначеного періоду зберігання, що відповідає сучасним вимогам до забезпечення інформаційної безпеки та проведення цифрової криміналістики.

Крім того, у Microsoft Sentinel було створено аналітичне правило для автоматичного виявлення багаторазових невдалих спроб автентифікації SSH. Під час тестування правило успішно формувало інциденти безпеки, що підтвердило працездатність реалізованого механізму виявлення атак.

З метою автоматизації реагування було розроблено робочий процес Azure Logic Apps, який забезпечує автоматичну обробку інцидентів Microsoft Sentinel. Реалізований Workflow дозволяє додавати коментарі до інцидентів і підготовлений до автоматичного надсилання повідомлень електронною поштою після завершення процедури авторизації відповідного поштового сервісу.

Таким чином, у третьому розділі було повністю реалізовано програмно-технічну інфраструктуру запропонованої системи моніторингу інформаційної безпеки, яка забезпечує централізований збір журналів, їх захищене зберігання, автоматичне виявлення кіберінцидентів та підтримку механізмів автоматизованого реагування. Отримані результати стали основою для проведення експериментального дослідження ефективності системи, яке буде наведено у четвертому розділі дипломної роботи.

87

РОЗДІЛ 4. ТЕСТУВАННЯ ТА ОЦІНКА ЕФЕКТИВНОСТІ

4.1 Методика тестування

Метою тестування є перевірка працездатності реалізованої безпечної хмарної інфраструктури, оцінка ефективності реалізованих механізмів захисту та підтвердження можливості своєчасного виявлення й обробки подій інформаційної безпеки в середовищі Microsoft Azure.[4], [13], [14], [15]

Тестування проводилося після завершення розгортання всіх основних компонентів системи, описаних у третьому розділі роботи. До складу тестового середовища входили віртуальна машина Linux Ubuntu, служби Microsoft Azure Entra ID, Azure Monitor, Log Analytics Workspace, Microsoft Sentinel, Azure Storage із політикою незмінності журналів (Immutability Policy), а також Azure Logic Apps для автоматизації реагування на інциденти. Основною метою тестування було підтвердження коректної взаємодії всіх компонентів запропонованої архітектури та перевірка працездатності повного циклу обробки подій безпеки: від їх виникнення до автоматичного створення інциденту й запуску механізму

реагування.

Для оцінювання роботи системи було сформовано низку контрольованих сценаріїв тестування, які імітували типові події інформаційної безпеки без створення ризиків для сторонніх інформаційних систем. Усі експерименти виконувалися виключно у власному хмарному середовищі Microsoft Azure, що забезпечило повний контроль над тестовими даними та відповідність етичним вимогам проведення дослідження.

Під час тестування перевірялися такі функціональні можливості системи:

- автентифікація користувачів та контроль доступу за допомогою Microsoft Entra ID і моделі Role-Based Access Control;
- централізований збір журналів подій засобами Azure Monitor та Log Analytics Workspace;
- передача системних журналів із віртуальної машини Linux до централізованого сховища;
- захист журналів подій від модифікації та видалення за допомогою Azure Storage Immutability Policy;
- виявлення підозрілої активності засобами Microsoft Sentinel;
- автоматичне створення оповіщень (Alerts) та інцидентів (Incidents);
- виконання сценарію автоматизованого реагування за допомогою Azure Logic Apps;

88

- формування повідомлень про інциденти безпеки.

Для перевірки працездатності системи було використано метод контрольованого експерименту. Як тестовий сценарій обрано моделювання багаторазових невдалих спроб SSH-автентифікації до віртуальної машини Linux, що відповідає типовій атаці типу Brute Force.

Після генерації відповідних подій здійснювалася перевірка їх проходження через усі компоненти системи: Azure Monitor, Log Analytics Workspace, Microsoft Sentinel та Azure Logic Apps.

Ефективність запропонованого рішення оцінювалася за такими критеріями:

- коректність автентифікації та авторизації користувачів;
- повнота збору журналів подій;
- цілісність журналів безпеки;
- своєчасність виявлення підозрілої активності;
- автоматичне створення оповіщень та інцидентів;
- працездатність механізмів автоматизованого реагування;
- загальна інтеграція компонентів системи.

Для систематизації результатів перевірки було сформовано тестові сценарії, наведені в таблиці 4.1.

Таблиця 4.1 – Програма тестування реалізованої системи

№ Об'єкт тестування Очікуваний результат

- 1 Автентифікація та авторизація Коректне застосування Entra ID та RBAC
- 2 Azure Monitor Передача телеметрії до Log Analytics
- 3 Log Analytics Workspace Централізоване зберігання журналів
- 4 Azure Storage Immutability Нemoжливiсть змiни або видалення журналів
- 5 Detection Rules Автоматичне виявлення підозрілих подій
- 6 Microsoft Sentinel Створення Alert та Incident
- 7 Azure Logic Apps Автоматичний запуск сценарію реагування
- 8 Система сповіщень Формування повідомлення про інцидент

4.2 Перевірка механізмів автентифікації та авторизації

Метою даного етапу тестування була перевірка працездатності механізмів автентифікації та авторизації, реалізованих у хмарному середовищі Microsoft Azure. Особлива увага приділялася перевірці коректності роботи служби Microsoft Entra ID, механізму

89

керування доступом Role-Based Access Control (RBAC), а також контролю доступу до окремих ресурсів хмарної інфраструктури.

Перед початком тестування було створено користувачів та групи безпеки у Microsoft Entra ID, після чого кожному користувачу було призначено відповідні ролі доступу до ресурсів Azure. Для адміністратора системи використовувалася роль Owner, яка надає повний контроль над ресурсами підписки, тоді як для інших користувачів могли застосовуватися ролі з обмеженими привілеями, наприклад Reader або Contributor.

Під час тестування виконувалися такі перевірки:

- успішна автентифікація користувача в Microsoft Azure Portal;

- перевірка застосування ролей RBAC;
- перевірка можливості доступу до ресурсів лише відповідно до призначених прав;
- підтвердження неможливості виконання адміністративних операцій користувачами без необхідних привілеїв.

Після входу до Azure Portal система успішно автентифікувала користувача через Microsoft Entra ID. Далі було перевірено призначені ролі доступу до ресурсів підписки Azure. Встановлено, що користувач із роллю Owner має повний доступ до створення, зміни та видалення ресурсів, тоді як права інших ролей обмежуються політиками RBAC.

Рисунок 4.1 – Призначення ролі користувачу в Microsoft Entra ID (RBAC)

Під час тестування також було перевірено можливість доступу до основних компонентів реалізованої системи:

90

- Virtual Machine;
- Log Analytics Workspace;
- Microsoft Sentinel;
- Azure Storage Account;
- Azure Logic Apps.

Усі ресурси відкривалися лише після успішної автентифікації користувача в Microsoft Entra ID, що підтверджує коректну роботу централізованого механізму керування доступом. Додатково було перевірено журнал активності Azure, який містить інформацію про всі операції автентифікації та зміни конфігурації ресурсів. Це дозволяє проводити аудит адміністративних дій та забезпечує простежуваність виконаних операцій.

Рисунок 4.2 – Журнал активності Azure із записами про операції автентифікації та керування ресурсами.

На рисунку 4.2 наведено журнал активності Azure Resource Manager для групи ресурсів rg-thesis-dev. Журнал містить інформацію про адміністративні операції, виконані користувачем під час налаштування хмарної інфраструктури, зокрема створення та модифікацію підключень Logic Apps, роботу з ключами доступу та інші операції керування ресурсами. Для кожної події відображаються час виконання, статус операції, підписка та користувач, який її ініціював. Це дозволяє здійснювати аудит адміністративних дій і контролювати виконання операцій у середовищі Azure.

91

4.3. Тестування централізованого логування

Метою даного етапу було перевірити працездатність централізованого механізму збору журналів подій із віртуальної машини Linux до середовища Azure Monitor та Log Analytics Workspace. Особлива увага приділялася перевірці коректності передачі телеметрії, системних журналів Syslog та журналів автентифікації SSH.

Перед початком тестування на віртуальній машині vm-thesis було встановлено агент Azure Monitor Agent (AMA), який забезпечує передачу телеметрії до Log Analytics Workspace. Збір даних здійснювався відповідно до налаштованого Data Collection Rule, що визначає типи журналів, які необхідно централізовано збирати.

Для перевірки працездатності системи було виконано запит до таблиці Heartbeat, яка містить службову інформацію про підключені агенти моніторингу. Отримані результати підтвердили регулярне надходження службових повідомлень від віртуальної машини vm-thesis, що свідчить про успішне функціонування Azure Monitor Agent та його стабільне підключення до Log Analytics Workspace.

Рисунок 4.3 – Записи Heartbeat у Log Analytics Workspace, що підтверджують успішну передачу телеметрії від віртуальної машини vm-thesis.

Наступним етапом було перевірено надходження системних журналів Syslog, які формуються операційною системою Ubuntu під час роботи служб та виконання адміністративних операцій. Для цього було виконано KQL-запит до таблиці Syslog, після чого

система відобразила записи від різних системних сервісів, зокрема sshd, daemon systemd та інших компонентів операційної системи.

Отримані результати підтвердили, що журнали успішно передаються до Log Analytics Workspace у режимі реального часу та можуть використовуватися для подальшого аналізу засобами Microsoft Sentinel.

Рисунок 4.4 – Системні журнали Syslog, отримані від віртуальної машини vm-thesis у Log Analytics Workspace.

Окремо було перевірено надходження журналів автентифікації SSH. Для цього було виконано фільтрацію записів процесу sshd, що дозволило виділити лише повідомлення, пов'язані зі спробами входу до системи.

У результаті було отримано записи про успішні та невдалі спроби автентифікації, IP-адреси джерел підключення, імена користувачів та службові повідомлення процесу SSH. Саме ці журнали в подальшому використовуються Microsoft Sentinel для виявлення атак типу Brute Force та генерації інцидентів інформаційної безпеки.

Рисунок 4.5 – Журнали автентифікації SSH, отримані із Syslog та використані для подальшого аналізу в Microsoft Sentinel.

Для оцінювання працездатності централізованого логування було узагальнено результати проведених перевірок.

Таблиця 4.2 – Результати тестування централізованого логування

Перевірка	Результат
Передача Heartbeat	Успішно
Передача Syslog	Успішно
Передача журналів SSH	Успішно
Надходження телеметрії до Log Analytics	Успішно
Виконання KQL-запитів	Успішно

За результатами тестування встановлено, що реалізована система централізованого логування функціонує коректно. Azure Monitor Agent забезпечує безперервну передачу телеметрії, а Log Analytics Workspace успішно накопичує службові журнали операційної системи, журнали автентифікації та інші події безпеки. Отримані журнали можуть використовуватися Microsoft Sentinel для автоматизованого аналізу, побудови правил виявлення атак та формування інцидентів інформаційної безпеки.

4.4 Перевірка цілісності журналів подій

Метою даного етапу тестування була перевірка працездатності механізму забезпечення незмінності журналів подій (Immutability Policy), реалізованого засобами Azure Storage. Під час дослідження перевірялося, чи забезпечує система захист журналів безпеки від несанкціонованого видалення або модифікації після їх збереження.

Для реалізації захисту було використано Azure Storage Account, у якому створено контейнер securitylogs. До контейнера застосовано політику Time-based Immutability, яка встановлює період зберігання об'єктів тривалістю 30 днів. Після активації політики всі файли, що знаходяться в контейнері, стають захищеними від змін та видалення до завершення визначеного строку.

На першому етапі тестування було перевірено правильність застосування політики незмінності. У властивостях контейнера Azure Storage відображається активна політика із зазначенням типу захисту, області застосування та встановленого строку зберігання.

Рисунок 4.6 – Політика Time-based Immutability, застосована до контейнера securitylogs.

Після підтвердження правильності налаштування політики було перевірено можливість збереження журналів подій у контейнері. До контейнера було завантажено тестовий файл, що імітує журнал безпеки. Після завершення завантаження було перевірено його успішне збереження у сховищі Azure Blob Storage.

95

Рисунок 4.7 – Контейнер securitylogs із тестовим файлом журналу подій

Наступним етапом тестування була перевірка захисту журналів від несанкціонованого видалення. Було здійснено спробу видалення файлу із контейнера, який перебуває під дією політики незмінності. Azure Storage автоматично заблокував виконання цієї операції відповідно до встановленої політики Time-based Immutability. У результаті система не дозволила видалити об'єкт до завершення строку зберігання, що підтверджує коректну роботу механізму захисту журналів подій.

Крім того, інформація про спробу видалення журналу була зареєстрована у журналах Azure Monitor та могла бути використана Microsoft Sentinel для подальшого аналізу інциденту інформаційної безпеки. Таким чином було підтверджено, що журнали подій після збереження залишаються доступними лише для читання та не можуть бути змінені або видалені протягом встановленого строку зберігання.

Таблиця 4.3 – Результати перевірки механізму Immutability Policy

Перевірка	Результат
Контейнер створено	
Політика Time-based Immutability застосована	
Термін зберігання	30 днів
Завантаження журналу	
Видалення файлу	заблоковано
Цілісність журналів	забезпечено

96

За результатами проведеного тестування встановлено, що використання Azure Storage Immutability Policy забезпечує ефективний захист журналів подій від несанкціонованої модифікації та видалення. Реалізований механізм відповідає сучасним вимогам до забезпечення цілісності цифрових доказів та може використовуватися як елемент побудови захищених систем моніторингу інформаційної безпеки. Отримані результати підтверджують можливість застосування політики незмінності для довгострокового зберігання журналів безпеки та підтримки процесів аудиту й розслідування інцидентів.

4.5 Симуляція атак та підозрілої активності

Метою даного етапу тестування було моделювання підозрілої активності у хмарному середовищі Microsoft Azure та перевірка здатності реалізованої системи виявляти потенційні загрози інформаційній безпеці. Для цього було використано контрольований сценарій імітації атаки типу Brute Force на сервіс Secure Shell (SSH), який є одним із найбільш поширених способів несанкціонованого отримання доступу до серверів. [21], [22], [23], [7]

Усі експерименти проводилися виключно у власному тестовому середовищі Microsoft Azure без використання сторонніх інформаційних систем або ресурсів. Це забезпечило повний контроль над процесом тестування та відповідність етичним вимогам проведення досліджень у сфері кібербезпеки.

У ході тестування було здійснено багаторазові спроби підключення до віртуальної машини vm-thesis із використанням неправильних облікових даних. Кожна невдала спроба автентифікації автоматично реєструвалася службою sshd операційної системи Linux та передавалася до Azure Monitor Agent.

Після надходження журналів до Log Analytics Workspace записи автоматично стали доступними для подальшого аналізу засобами Microsoft Sentinel. Це дозволило оцінити повний цикл проходження подій інформаційної безпеки від моменту виникнення до їх централізованої обробки.

Рисунок 4.8 – Журнали багаторазових невдалих SSH-автентифікацій, отримані у Log Analytics Workspace

Після отримання журналів було виконано їх аналіз за допомогою мови запитів Kusto Query Language (KQL). Для цього використано спеціально створений запит, який виконує пошук багаторазових невдалих спроб SSH-автентифікації протягом визначеного інтервалу часу.

У результаті виконання запиту було виявлено перевищення встановленого порогу невдалих входів, що свідчило про наявність ознак атаки типу Brute Force.

Рисунок 4.9 – Результати виконання KQL-запиту для виявлення багаторазових невдалих SSH-автентифікацій

Таблиця 4.4 – Результати симуляції атаки

Параметр	Значення
Тип атаки	SSH Brute Force
Ціль	vm-thesis
Джерело журналів	Syslog
Передача журналів	Azure Monitor Agent
Аналіз журналів	Microsoft Sentinel
Результат	Ознаки атаки успішно виявлено

Проведене тестування підтвердило працездатність запропонованої системи моніторингу. Усі створені під час симуляції журнали були успішно передані до Log Analytics Workspace та проаналізовані Microsoft Sentinel. Отримані результати стали основою для автоматичного спрацювання правила виявлення інцидентів, яке буде детально розглянуто у наступному підрозділі.

4.6 Перевірка роботи Detection Rules

Метою даного етапу тестування була перевірка працездатності створених правил виявлення інцидентів (Detection Rules) у Microsoft Sentinel та оцінка їх здатності автоматично виявляти підозрілу активність на основі журналів безпеки, що надходять до Log Analytics Workspace.

Для тестування використовувалося створене у третьому розділі аналітичне правило Multiple Failed SSH Logins, реалізоване як Scheduled Analytics Rule. Правило призначене для автоматичного аналізу журналів Syslog та виявлення багаторазових невдалих спроб автентифікації через сервіс Secure Shell (SSH).

Принцип роботи правила полягає у періодичному виконанні Kusto Query Language (KQL)-запиту, який аналізує журнали Syslog, отримані від процесу sshd. У разі перевищення встановленого порога кількості невдалих спроб входу система автоматично формує сповіщення (Alert), яке надалі використовується для створення інциденту інформаційної безпеки.

Під час проведення експерименту було виконано серію невдалих SSH-автентифікацій до віртуальної машини vm-thesis, після чого Microsoft Sentinel автоматично запустив створене правило аналізу журналів.

Рисунок 4.10 – Аналітичне правило "Multiple Failed SSH Logins" у Microsoft Sentinel

Після запуску правила було виконано аналіз журналів Syslog за допомогою KQL-запиту. У результаті аналізу система виявила тринадцять невдалих спроб автентифікації, що перевищує встановлений поріг спрацювання правила. Отриманий результат підтвердив правильність роботи алгоритму аналізу журналів та відповідність реалізованого правила вимогам щодо автоматичного виявлення атак типу Brute Force.

Рисунок 4.11 – Інцидент безпеки, автоматично створений Microsoft Sentinel після спрацювання аналітичного правила Multiple Failed SSH Logins

Для оцінювання ефективності роботи Detection Rule було проаналізовано основні параметри функціонування правила.

100

Таблиця 4.5 – Результати перевірки Detection Rule

Параметр Результат

Тип правила Scheduled Analytics Rule

Джерело журналів Syslog

Аналіз журналів KQL

Поріг спрацювання ≥ 5 невдалих входів

Фактичний результат 13 невдалих входів

Alert створено

Incident створено

Під час тестування також було перевірено відповідність Detection Rule методології MITRE ATT&CK. Створене правило класифікує виявлену активність як спробу отримання облікових даних (Credential Access) із використанням техніки Brute Force (T1110). Така класифікація дозволяє аналітикам швидко визначати характер загрози та використовувати стандартизований підхід до аналізу інцидентів.

Таблиця 4.6 – Відповідність Detection Rule матриці MITRE ATT&CK

Категорія Значення

Тактика Credential Access

Техніка T1110

Назва техніки Brute Force

За результатами проведеного тестування встановлено, що реалізоване Detection Rule функціонує коректно та забезпечує автоматичне виявлення багаторазових невдалих спроб SSH-автентифікації. Після перевищення встановленого порога система автоматично формує сповіщення, яке використовується Microsoft Sentinel для створення інциденту безпеки. Отримані результати підтверджують ефективність використання Detection Rules як одного з основних механізмів виявлення кіберзагроз у запропонованій хмарній архітектурі.

4.7 Перевірка роботи Microsoft Sentinel

Метою даного етапу тестування була перевірка працездатності платформи Microsoft Sentinel як централізованої системи управління подіями інформаційної безпеки (SIEM). Особлива

101

увага приділялася перевірці процесів створення сповіщень (Alerts), автоматичного формування інцидентів (Incidents), а також можливості подальшого аналізу виявлених подій безпеки.

Після виконання сценарію моделювання атаки типу Brute Force та спрацювання аналітичного правила Multiple Failed SSH Logins Microsoft Sentinel автоматично сформував сповіщення безпеки на основі отриманих журналів Syslog.

Створене сповіщення містило інформацію про джерело події, кількість невдалих спроб автентифікації, віртуальну машину, на якій було зафіксовано підозрілу активність, а також рівень критичності інциденту.

Рисунок 4.12 – Спрацювання аналітичного правила Multiple Failed SSH Logins у Microsoft Sentinel

Після формування сповіщення Microsoft Sentinel автоматично створив інцидент інформаційної безпеки. Інцидент об'єднав усі пов'язані події в єдину сутність, що спрощує подальший аналіз та розслідування потенційної атаки.

Під час перевірки було встановлено, що інцидент містить необхідні атрибути для проведення розслідування:

- назву інциденту;
- рівень критичності;
- час виникнення події;
- пов'язані сповіщення;
- інформацію про хост;

102

Рисунок 4.13 – Інцидент безпеки Multiple Failed SSH Logins, автоматично створений Microsoft Sentinel

Під час аналізу інциденту було підтверджено, що Microsoft Sentinel коректно пов'язує події між собою та автоматично створює об'єкти розслідування. Це дозволяє аналітику безпеки швидко отримати інформацію про характер загрози та оцінити потенційний вплив інциденту на інформаційну систему.

Для оцінювання ефективності роботи SIEM-платформи було узагальнено результати тестування.

Таблиця 4.7 – Результати перевірки Microsoft Sentinel

Перевірка	Результат
Отримання журналів із Log Analytics	
Аналіз журналів Detection Rule	
Формування Alert	
Створення Incident	
Відображення Severity	
Кореляція подій	
Підготовка даних для розслідування	

Окремо було перевірено відповідність створеного інциденту вимогам платформи MITRE ATT&CK. Microsoft Sentinel автоматично відніс інцидент до тактики Credential Access

103

та техніки Brute Force (T1110), що дозволяє використовувати стандартизований підхід до класифікації кіберзагроз.

Таблиця 4.8 – Класифікація інциденту за MITRE ATT&CK

Параметр	Значення
Тактика	Credential Access
Техніка	T1110
Назва техніки	Brute Force
Рівень критичності	Medium

За результатами тестування встановлено, що Microsoft Sentinel успішно виконує функції централізованого моніторингу подій безпеки та автоматичного управління інцидентами. Платформа коректно обробляє результати роботи Detection Rules, формує сповіщення та створює інциденти безпеки для подальшого аналізу. Отримані результати підтверджують доцільність використання Microsoft Sentinel як основного SIEM-компонента запропонованої хмарної архітектури.

4.8 Перевірка автоматизованого реагування

Метою даного етапу тестування була перевірка працездатності механізму автоматизованого реагування на інциденти інформаційної безпеки, реалізованого засобами Azure Logic Apps. Під час дослідження оцінювалася коректність запуску робочого процесу після створення інциденту Microsoft Sentinel та виконання визначених дій без участі адміністратора.

У межах дипломного проєкту було реалізовано робочий процес blob-delete-response, який інтегровано з Microsoft Sentinel. Після створення нового інциденту безпеки Logic App автоматично запускається та виконує послідовність визначених дій.

До складу реалізованого Workflow входять такі етапи:

- отримання інформації про інцидент від Microsoft Sentinel;
- автоматичне додавання службового коментаря до картки інциденту;
- підготовка до надсилання повідомлення через сервіс Office 365 Outlook.

104

Рисунок 4.14 – Робочий процес Azure Logic Apps для автоматизованого реагування на інциденти Microsoft Sentinel

Під час тестування було підтверджено, що після створення інциденту Microsoft Sentinel коректно передає інформацію до Azure Logic Apps. Робочий процес успішно запускається та виконує налаштовану дію Add Comment to Incident (V3), що підтверджує працездатність механізму автоматизованого реагування.

Також було виконано перевірку можливості інтеграції Azure Logic Apps із сервісом Office 365 Outlook для автоматичного надсилання повідомлень відповідальним особам.

Рисунок 4.15 – Налаштування дії Send an Email (V2) у Azure Logic Apps

105

Під час тестування встановлено, що виконання цієї операції потребує додаткової авторизації сервісу Office 365 Outlook. У навчальному середовищі Microsoft Azure завершити процедуру авторизації не вдалося, у зв'язку з чим функція автоматичного надсилання повідомлень залишилася підготовленою до використання, але не була повністю протестована. Для надсилання повідомлень про інциденти до автоматизованого сценарію Azure Logic Apps було додано дію Send an Email (V2). Під час тестування встановлено, що виконання цього етапу не завершилося успішно через проблему авторизації сервісу Office 365 Outlook. Незважаючи на це, попередні етапи сценарію (отримання інциденту Microsoft Sentinel та додавання коментаря) були налаштовані коректно, що підтверджує працездатність основної логіки автоматизованого реагування.

Таблиця 4.9 – Результати перевірки автоматизованого реагування

Перевірка	Результат
Запуск Logic App після створення Incident	
Отримання інформації про інцидент	
Виконання Add Comment to Incident	
Підключення Office 365 Outlook	Частково
Автоматичне Email-сповіщення	Не завершено через авторизацію

За результатами тестування встановлено, що реалізований механізм автоматизованого реагування функціонує коректно в частині інтеграції Microsoft Sentinel із Azure Logic Apps. Робочий процес автоматично запускається після створення інциденту та виконує визначені дії без участі адміністратора. Функція автоматичного надсилання повідомлень підготовлена до використання, однак її повне тестування потребує завершення авторизації Office 365 Outlook у виробничому середовищі.

4.9 Порівняльна оцінка запропонованого рішення

Після завершення тестування було проведено порівняльну оцінку розробленої системи із традиційним підходом до моніторингу інформаційної безпеки, який не використовує централізовані засоби аналізу журналів подій та автоматизованого реагування.[1], [5], [6], [2]

Основною перевагою запропонованої архітектури є інтеграція декількох сервісів Microsoft Azure в єдину систему моніторингу інформаційної безпеки. На відміну від традиційного підходу, де журнали подій аналізуються вручну або зберігаються локально,

106

запропоноване рішення забезпечує централізований збір журналів, автоматичне виявлення інцидентів та підтримку механізмів автоматизованого реагування.

Таблиця 4.10 – Порівняння запропонованого рішення з традиційним підходом

Критерій	Традиційний підхід	Запропоноване рішення
Централізований збір журналів	Відсутній або частковий	Реалізовано
Захищене зберігання журналів	Не гарантується	Azure Immutability Policy
Автоматичне виявлення атак	Відсутнє	Microsoft Sentinel
Автоматичне створення інцидентів	Відсутнє	Реалізовано
Автоматизоване реагування	Відсутнє	Azure Logic Apps
Масштабованість	Обмежена	Висока
Інтеграція компонентів	Часткова	Повністю інтегрована

Проведене порівняння показало, що запропонована система значно підвищує ефективність моніторингу інформаційної безпеки за рахунок автоматизації процесів збору журналів, аналізу подій та реагування на інциденти.

4.10 Аналіз отриманих результатів

У процесі виконання експериментального дослідження було підтверджено працездатність усіх основних компонентів запропонованої системи моніторингу інформаційної безпеки.

Проведене тестування засвідчило коректну роботу Azure Monitor Agent та успішну передачу телеметрії від віртуальної машини Linux до Log Analytics Workspace. Отримані журнали подій були успішно використані Microsoft Sentinel для аналізу потенційних загроз.

Під час симуляції атаки типу Brute Force Detection Rule Multiple Failed SSH Logins успішно виявило багаторазові невдалі спроби автентифікації та автоматично сформувало сповіщення безпеки. Microsoft Sentinel коректно створив інцидент, який містив необхідну інформацію для подальшого аналізу.

Також було підтверджено працездатність механізму захисту журналів подій за допомогою Azure Storage Immutability Policy. Застосування політики незмінності забезпечує

107

захист журналів від модифікації та видалення, що є важливим під час проведення цифрової криміналістики та аудиту інформаційної безпеки.

Реалізований механізм автоматизованого реагування на базі Azure Logic Apps забезпечив автоматичний запуск Workflow після створення інциденту Microsoft Sentinel.

Підключення сервісу Office 365 Outlook потребує додаткової авторизації, однак архітектура рішення повністю підготовлена до подальшого використання.

Загалом результати проведеного дослідження підтвердили ефективність запропонованої архітектури та її відповідність поставленим вимогам щодо централізованого моніторингу інформаційної безпеки у хмарному середовищі Microsoft Azure.

4.11 Етичні та правові аспекти дослідження

Під час виконання дипломної роботи особлива увага приділялася дотриманню етичних принципів проведення досліджень у сфері інформаційної безпеки. Усі експериментальні дії виконувалися виключно у власному тестовому середовищі Microsoft Azure без використання сторонніх інформаційних систем або ресурсів. [15], [11], [33], [34]

Моделювання атак здійснювалося лише щодо власної віртуальної машини vm-thesis, яка була створена спеціально для проведення дослідження. У процесі тестування не виконувалися дії, що могли б призвести до порушення конфіденційності, цілісності або доступності інформації інших користувачів.

Робота із сервісами Microsoft Azure здійснювалася відповідно до умов використання платформи та чинного законодавства у сфері захисту інформації. Для автентифікації користувачів використовувалися механізми Microsoft Entra ID, а керування правами доступу реалізовано відповідно до принципу мінімально необхідних привілеїв.

Отримані журнали подій використовувалися виключно з навчальною та дослідницькою метою. Персональні дані сторонніх осіб під час виконання дослідження не оброблялися, що забезпечує відповідність основним принципам захисту персональних даних та академічної доброчесності.

Таким чином, проведене дослідження відповідає сучасним етичним вимогам до виконання робіт у сфері кібербезпеки та не суперечить чинним правовим нормам.

Висновки до четвертого розділу

У четвертому розділі дипломної роботи проведено комплексне тестування реалізованої системи моніторингу інформаційної безпеки, побудованої на базі сервісів Microsoft Azure.

108

Перевірено працездатність усіх основних компонентів архітектури, починаючи з механізмів автентифікації та централізованого збору журналів подій і завершуючи автоматичним виявленням інцидентів та запуском механізмів автоматизованого реагування.

У процесі тестування підтверджено коректну роботу Microsoft Entra ID та моделі Role-Based Access Control, що забезпечують централізоване керування доступом до ресурсів хмарної інфраструктури. Також встановлено, що Azure Monitor Agent та Log Analytics Workspace забезпечують безперервний збір і централізоване зберігання журналів подій операційної системи Linux.

Особливу увагу було приділено перевірці механізму захисту журналів подій.

Використання Azure Storage Immutability Policy забезпечило можливість довгострокового захищеного зберігання журналів безпеки без ризику їх несанкціонованої модифікації або

видалення.

Під час моделювання атаки типу Brute Force підтверджено ефективність роботи Microsoft Sentinel та створених Detection Rules. Система автоматично виявила підозрілу активність, сформуvala сповіщення та створила інцидент безпеки, що підтверджує працездатність реалізованої SIEM-архітектури.

Крім того, перевірено роботу Azure Logic Apps, які забезпечують автоматичний запуск сценарію реагування після створення інциденту. Незважаючи на необхідність додаткової авторизації сервісу Office 365 Outlook для реалізації автоматичного надсилання повідомлень, архітектура рішення повністю підтримує можливість подальшого розширення функціональності.

Отримані результати підтверджують, що розроблена система відповідає поставленим у роботі вимогам та забезпечує ефективний моніторинг подій інформаційної безпеки, централізований аналіз журналів, автоматичне виявлення кіберзагроз і підтримку механізмів автоматизованого реагування. Запропоноване рішення може бути використане як основа для побудови сучасних систем моніторингу інформаційної безпеки в хмарних середовищах Microsoft Azure.

109

РОЗДІЛ 5. ЕКОНОМІЧНЕ ТА ПРАКТИЧНЕ ОБҐРУНТУВАННЯ

5.1 Оцінка вартості реалізації рішення

Однією з важливих переваг запропонованого рішення є можливість його реалізації з мінімальними фінансовими витратами на етапі розробки та тестування. У рамках даного дипломного проєкту було використано хмарну платформу Microsoft Azure та безкоштовні або умовно-безкоштовні сервіси, доступні в межах Azure Free Tier та навчальної підписки [4], [13], [14], [15]

Основними компонентами системи є Azure Entra ID для керування ідентифікацією та доступом, Azure Monitor для збору телеметрії, Log Analytics Workspace для централізованого зберігання журналів, Microsoft Sentinel для виявлення інцидентів безпеки, Azure Storage Account для незмінного зберігання журналів та Azure Logic Apps для автоматизації реагування на інциденти.

Таблиця 5.1 – Орієнтовна вартість компонентів рішення

Компонент	Призначення	Вартість MVP
Azure Entra ID	IAM та RBAC	Free
Azure Monitor	Моніторинг	Free Tier
Log Analytics Workspace	Централізоване логування	Free Tier
Microsoft Sentinel	SIEM	Trial / Free
Azure Storage	WORM Storage	до кількох євро
Azure Logic Apps	SOAR	мінімальна
Terraform	IaC	Free

Загальна вартість створення MVP у межах даної роботи є близькою до нуля, оскільки використовувалися безкоштовні можливості платформи Azure. Це дозволяє реалізувати подібне рішення навіть для невеликих організацій без значних інвестицій.

Для промислової експлуатації вартість буде залежати від обсягу журналів, кількості підключених ресурсів, тривалості зберігання даних та кількості автоматизованих сценаріїв реагування.

110

5.2 Аналіз економічної ефективності використання Azure Free Tier

Під час реалізації дипломного проєкту було максимально використано можливості Azure Free Tier та навчальної підписки Azure. [4], [13], [14], [15]

Основною перевагою такого підходу є можливість створення повноцінного прототипу системи моніторингу інформаційної безпеки без придбання дорогих комерційних продуктів.

У межах безкоштовного середовища вдалося реалізувати:

- централізований збір журналів;
- аналіз подій безпеки;
- створення аналітичних правил;

- генерацію інцидентів;
- автоматизоване реагування;
- захищене зберігання журналів.

Таблиця 5.2 – Сервіси Azure Free Tier, використані під час реалізації MVP

Сервіс Використання в проєкті

Azure Entra ID Автентифікація та контроль доступу

Azure Monitor Моніторинг ресурсів

Log Analytics Workspace Збір та аналіз логів

Azure Storage Незмінне зберігання журналів

Logic Apps Автоматизація процесів

Sentinel Виявлення інцидентів

Водночас використання безкоштовної підписки має певні обмеження:

- обмежений обсяг журналів;
- обмежений період зберігання даних;
- відсутність частини корпоративних функцій;
- обмеження на кількість автоматизованих операцій.

Незважаючи на це, безкоштовні можливості Azure є достатніми для створення MVP та проведення дослідження ефективності сучасної SIEM-системи.

5.3 Практична цінність та сфери застосування

Практична цінність реалізованого рішення полягає у створенні комплексної системи моніторингу безпеки, яка забезпечує централізований збір журналів, виявлення інцидентів та автоматизоване реагування. [1], [5], [6], [7]

111

Рисунок 5.1 – Архітектура реалізованого MVP-рішення із використанням сервісів Microsoft Azure.

Запропонована архітектура може використовуватися:

- у малих та середніх підприємствах;
- у навчальних закладах;
- у хмарних середовищах Azure;
- для побудови власного SOC;
- для аудиту безпеки інфраструктури.

112

Рішення дозволяє своєчасно виявляти підозрілу активність та зменшувати ризики компрометації інформаційних систем.

Основними практичними результатами роботи стали:

1. Реалізація централізованого журналювання подій.
2. Побудова SIEM-рішення на базі Microsoft Sentinel.
3. Виявлення спроб SSH Brute Force.
4. Виявлення спроб видалення захищених журналів.
5. Автоматизоване реагування через Azure Logic Apps.
6. Реалізація незмінного зберігання журналів за допомогою WORM-політик.

Отримані результати демонструють можливість створення ефективної системи моніторингу інформаційної безпеки з використанням сучасних хмарних сервісів Microsoft Azure.

5.4 Можливості масштабування та подальшого розвитку

Розроблене рішення створювалося як MVP, однак архітектура дозволяє масштабувати його до повноцінної корпоративної системи моніторингу безпеки. [1], [5], [6], [24]

Основними напрямками подальшого розвитку є:

- підключення додаткових джерел журналів;
- інтеграція з Microsoft Defender for Cloud;
- інтеграція з Microsoft Defender XDR;
- використання UEBA (User and Entity Behavior Analytics);
- автоматичне блокування облікових записів;
- автоматична ізоляція скомпрометованих ресурсів;

- використання Machine Learning для виявлення аномалій;
- інтеграція з AWS та Google Cloud Platform.

Таблиця 5.3 – Перспективи розвитку системи

Напрямок розвитку Практичний ефект

Microsoft Defender for Cloud Розширення моніторингу загроз

UEBA Аналіз поведінки користувачів

Автоматичне блокування Скорочення часу реагування

Multi-cloud Захист AWS та GCP

Machine Learning Підвищення точності виявлення атак

113

Масштабування рішення дозволить перетворити створений прототип на повноцінну платформу для забезпечення кібербезпеки організації.

Проведений аналіз показав, що запропонована архітектура може використовуватися не лише як навчальний прототип, а й як основа для створення корпоративної системи моніторингу інформаційної безпеки. Використання сервісів Microsoft Azure забезпечує модульність, масштабованість та можливість інтеграції з додатковими засобами захисту, включаючи Microsoft Defender XDR, Microsoft Defender for Cloud, Microsoft Purview та сторонні SIEM-рішення. Це дозволяє адаптувати систему до потреб організацій різного масштабу без суттєвої зміни її архітектури.

Висновки до п'ятого розділу

У розділі проведено економічне та практичне обґрунтування реалізованого рішення.

Встановлено, що створений прототип може бути реалізований із мінімальними фінансовими витратами завдяки використанню Azure Free Tier та безкоштовних інструментів автоматизації.

Показано, що запропонована система має практичну цінність для організацій, які потребують централізованого моніторингу безпеки, захисту журналів та автоматизованого реагування на інциденти.

Проведений аналіз підтвердив можливість подальшого масштабування рішення до рівня корпоративної системи моніторингу безпеки із використанням додаткових сервісів Microsoft Security та технологій поведінкового аналізу.

114

ЗАГАЛЬНІ ВИСНОВКИ

У магістерській роботі виконано проектування, реалізацію та практичне дослідження безпечної хмарної інфраструктури на платформі Microsoft Azure із використанням сучасних засобів моніторингу, централізованого логування, виявлення кіберінцидентів та автоматизованого реагування. Актуальність роботи зумовлена зростанням кількості кіберзагроз, необхідністю забезпечення безперервного моніторингу хмарних ресурсів і підвищенням рівня захисту корпоративних інформаційних систем.

У процесі виконання роботи було проаналізовано сучасні підходи до забезпечення інформаційної безпеки хмарних середовищ, принципи побудови Security Operations Center (SOC), особливості використання сервісів Microsoft Azure, Microsoft Sentinel, Azure Monitor, Log Analytics Workspace та Azure Logic Apps. На основі проведеного аналізу розроблено архітектуру безпечної хмарної інфраструктури, яка забезпечує централізований збір журналів подій, їх аналіз, автоматичне виявлення потенційних загроз і підтримку процесів реагування на інциденти.

Практична реалізація проекту виконана із застосуванням концепції Infrastructure as Code за допомогою Terraform, що дозволило автоматизувати розгортання основних компонентів інфраструктури та забезпечити відтворюваність процесу її створення. Для централізованого моніторингу реалізовано використання Azure Monitor та Log Analytics Workspace, які забезпечують збір телеметрії, системних журналів і журналів автентифікації від віртуальної машини Linux.

Одним із ключових результатів роботи стало впровадження Microsoft Sentinel як SIEM-платформи для аналізу подій інформаційної безпеки. Створено аналітичне правило Multiple Failed SSH Logins, яке дозволяє автоматично виявляти багаторазові невдалі спроби SSH-автентифікації. Під час експериментального тестування підтверджено коректне формування сповіщень та автоматичне створення інцидентів безпеки на основі результатів виконання KQL-запитів.

Для підвищення рівня захисту журналів подій реалізовано політику незмінності (Time-based Immutability Policy) для контейнера Azure Storage, що забезпечує захист журналів від модифікації або видалення протягом визначеного періоду зберігання. Проведене тестування підтвердило працездатність механізму та його відповідність вимогам забезпечення цілісності журналів.

У роботі також реалізовано автоматизоване реагування на інциденти із використанням Azure Logic Apps. Playbook успішно виконує автоматичне додавання службового коментаря

115

до інциденту Microsoft Sentinel. Спроба реалізації автоматичного надсилання повідомлень електронною поштою через Office 365 Outlook не була завершена через обмеження авторизації облікового запису, що не вплинуло на працездатність основної архітектури системи. Отримані результати підтверджують можливість подальшого розширення функціональності автоматизованого реагування.

У межах роботи проведено комплексне тестування всіх реалізованих компонентів.

Перевірено механізми автентифікації та авторизації на основі Azure RBAC, функціонування централізованого логування, захист журналів подій, працездатність правил виявлення загроз, формування інцидентів Microsoft Sentinel та виконання автоматизованих сценаріїв реагування. Результати тестування підтвердили стабільну роботу системи та досягнення поставлених функціональних вимог.

Отримані результати мають практичну цінність і можуть бути використані як основа для побудови невеликих корпоративних центрів моніторингу безпеки (SOC), навчальних лабораторій із кібербезпеки, а також для подальшого розвитку хмарних систем захисту інформації. Запропонована архітектура є масштабованою, підтримує інтеграцію з додатковими сервісами Microsoft Azure та може бути адаптована відповідно до потреб конкретної організації.

Таким чином, поставлена мета магістерської роботи досягнута повністю. Усі основні завдання дослідження виконані, а розроблена безпечна хмарна інфраструктура підтвердила свою працездатність, ефективність та можливість практичного використання для забезпечення моніторингу, виявлення та реагування на кіберінциденти у середовищі Microsoft Azure.

116

БІБЛІОГРАФІЯ

1. Microsoft, Azure Monitor documentation, 2026. [Online]. Available: <https://learn.microsoft.com/en-us/azure/azure-monitor/>. Accessed: Jun. 27, 2026.
2. Microsoft, Log Analytics workspace overview, 2026. [Online]. Available: <https://learn.microsoft.com/en-us/azure/azure-monitor/logs/log-analytics-workspace-overview>. Accessed: Jun. 27, 2026.
3. NIST, SP 800-92: Guide to Computer Security Log Management, 2006. [Online]. Available: <https://csrc.nist.gov/publications/detail/sp/800-92/final>. Accessed: Jun. 27, 2026.
4. Microsoft, Microsoft Azure documentation, 2026. [Online]. Available: <https://learn.microsoft.com/en-us/azure/>. Accessed: Jun. 27, 2026.
5. Microsoft, Azure Monitor Agent overview, 2026. [Online]. Available: <https://learn.microsoft.com/en-us/azure/azure-monitor/agents/azure-monitor-agent-overview>. Accessed: Jun. 27, 2026.
6. Microsoft, Azure Monitor pricing, 2026. [Online]. Available: <https://azure.microsoft.com/en-us/pricing/details/monitor/>. Accessed: Jun. 27, 2026.
7. Splunk, Splunk Enterprise Security documentation, 2026. [Online]. Available: <https://docs.splunk.com/Documentation/ES>. Accessed: Jun. 27, 2026.
8. HashiCorp, Terraform documentation, 2026. [Online]. Available: <https://developer.hashicorp.com/terraform/docs>. Accessed: Jun. 27, 2026.
9. HashiCorp, Terraform AzureRM provider documentation, 2026. [Online]. Available: <https://registry.terraform.io/providers/hashicorp/azurerm/latest/docs>. Accessed: Jun. 27, 2026.
10. HashiCorp, Infrastructure as Code with Terraform, 2026. [Online]. Available: <https://developer.hashicorp.com/terraform/intro>. Accessed: Jun. 27, 2026.
11. Microsoft, Azure security best practices and patterns, 2026. [Online]. Available: <https://learn.microsoft.com/en-us/azure/security/fundamentals/best-practices-and-patterns>. Accessed: Jun. 27, 2026.
12. Microsoft, Azure role-based access control documentation, 2026. [Online]. Available: <https://learn.microsoft.com/en-us/azure/role-based-access-control/>. Accessed: Jun. 27, 2026.
13. Microsoft, Azure Architecture Center documentation, 2026. [Online]. Available:

<https://learn.microsoft.com/en-us/azure/architecture/>. Accessed: Jun. 27, 2026.

14. Microsoft, Azure Well-Architected Framework, 2026. [Online]. Available: <https://learn.microsoft.com/en-us/azure/well-architected/>. Accessed: Jun. 27, 2026.

117

15. Microsoft, Microsoft cloud security benchmark documentation, 2026. [Online]. Available: <https://learn.microsoft.com/en-us/security/benchmark/azure/>. Accessed: Jun. 27, 2026.

16. Microsoft, Microsoft Sentinel documentation, 2026. [Online]. Available: <https://learn.microsoft.com/en-us/azure/sentinel/>. Accessed: Jun. 27, 2026.

17. Microsoft, Microsoft Sentinel incidents, 2026. [Online]. Available: <https://learn.microsoft.com/en-us/azure/sentinel/investigate-cases>. Accessed: Jun. 27, 2026.

18. Microsoft, Automate threat response with playbooks in Microsoft Sentinel, 2026. [Online]. Available: <https://learn.microsoft.com/en-us/azure/sentinel/automation/automate-responses-with-playbooks>. Accessed: Jun. 27, 2026.

19. Microsoft, Azure Logic Apps documentation, 2026. [Online]. Available: <https://learn.microsoft.com/en-us/azure/logic-apps/>. Accessed: Jun. 27, 2026.

20. NIST, SP 800-207: Zero Trust Architecture, 2020. [Online]. Available: <https://csrc.nist.gov/publications/detail/sp/800-207/final>. Accessed: Jun. 27, 2026.

21. MITRE, MITRE ATT&CK Enterprise Matrix, 2026. [Online]. Available: <https://attack.mitre.org/matrices/enterprise/>. Accessed: Jun. 27, 2026.

22. MITRE, ATT&CK Technique T1110: Brute Force, 2026. [Online]. Available: <https://attack.mitre.org/techniques/T1110/>. Accessed: Jun. 27, 2026.

23. MITRE, ATT&CK Tactic TA0006: Credential Access, 2026. [Online]. Available: <https://attack.mitre.org/tactics/TA0006/>. Accessed: Jun. 27, 2026.

24. Microsoft, Azure pricing calculator, 2026. [Online]. Available: <https://azure.microsoft.com/en-us/pricing/calculator/>. Accessed: Jun. 27, 2026.

25. Microsoft, Microsoft Sentinel pricing, 2026. [Online]. Available: <https://azure.microsoft.com/en-us/pricing/details/microsoft-sentinel/>. Accessed: Jun. 27, 2026.

26. Microsoft, Azure free account FAQ, 2026. [Online]. Available: <https://azure.microsoft.com/en-us/free/free-account-faq/>. Accessed: Jun. 27, 2026.

27. Microsoft, Microsoft Entra ID documentation, 2026. [Online]. Available: <https://learn.microsoft.com/en-us/entra/identity/>. Accessed: Jun. 27, 2026.

28. Microsoft, Zero Trust architecture with Microsoft Entra ID, 2026. [Online]. Available: <https://learn.microsoft.com/en-us/security/zero-trust/deploy/identity>. Accessed: Jun. 27, 2026.

29. Microsoft, Microsoft Zero Trust guidance, 2026. [Online]. Available: <https://learn.microsoft.com/en-us/security/zero-trust/>. Accessed: Jun. 27, 2026.

30. Microsoft, Data collection rules in Azure Monitor, 2026. [Online]. Available: <https://learn.microsoft.com/en-us/azure/azure-monitor/data-collection/data-collection-rule-overview>. Accessed: Jun. 27, 2026.

118

31. Microsoft, Kusto Query Language documentation, 2026. [Online]. Available: <https://learn.microsoft.com/en-us/kusto/query/>. Accessed: Jun. 27, 2026.

32. Wazuh, Wazuh documentation, 2026. [Online]. Available: <https://documentation.wazuh.com/>. Accessed: Jun. 27, 2026.

33. NIST, The NIST Cybersecurity Framework (CSF) 2.0, 2024. [Online]. Available: <https://csrc.nist.gov/pubs/cswp/29/the-nist-cybersecurity-framework-20/final>. Accessed: Jun. 27, 2026.

34. NIST, SP 800-53 Rev. 5: Security and Privacy Controls for Information Systems and Organizations, 2020. [Online]. Available: <https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final>. Accessed: Jun. 27, 2026.

35. Microsoft, Immutable storage for Azure Blob Storage, 2026. [Online]. Available: <https://learn.microsoft.com/en-us/azure/storage/blobs/immutable-storage-overview>. Accessed: Jun. 27, 2026.

36. Cloud Security Alliance, Security Guidance for Critical Areas of Focus in Cloud Computing v5.0, 2024. [Online]. Available: <https://cloudsecurityalliance.org/artifacts/security-guidance-v5>. Accessed: Jun. 27, 2026.

37. Microsoft, Configure immutability policies for blob versions, 2026. [Online]. Available: <https://learn.microsoft.com/en-us/azure/storage/blobs/immutable-policy-configure-version-scope>. Accessed: Jun. 27, 2026.